

# Proyecto de seguridad en aplicaciones móviles — Pipeline DevSecOps (CIB-204)

## Table of Contents

## PROYECTO DE SEGURIDAD EN APLICACIONES MÓVILES — PIPELINE DevSecOps

### Informe integrado: primer avance, segundo avance e informe final

**Curso:** CIB-204 · Seguridad del Software · Maestría en Ciberseguridad

**Universidad:** CENFOTEC · Sede Central **Profesora:** MsC. Alejandra Corrales

**Vargas Integrantes:** Eduardo J. Vega Arguedas y Keylor Elizondo Rodriguez

**Repositorio:** <https://github.com/edovega/proyecto-devsecops-cib204> **Fecha:** 19 de septiembre de 2026 **Código evaluado:** commit 0fc1c11 · **Run verde de**

**referencia:** 35442482331 (5/5 jobs en verde; CodeQL sin alertas abiertas)

El informe sigue la estructura establecida por el curso para el informe final: introducción, desarrollo, resumen de resultados, conclusiones y recomendaciones. Cada afirmación técnica remite a una evidencia EV-C204-XXX, verificable mediante docs/evidencias/manifiesto-sha256.txt.

---

### Mapa del documento

| Parte                                 | Secciones | Entrega        |
|---------------------------------------|-----------|----------------|
| Parte I — Contexto y diseño           | 1–8       | Primer Avance  |
| Parte II — Implementación y entorno   | 9–12      | Primer Avance  |
| Parte III — Diagnóstico y remediación | 13–15     | Segundo Avance |
| Parte IV — Pruebas y riesgos          | 16–18     | Segundo Avance |

| Parte                      | Secciones                                                                               | Entrega       |
|----------------------------|-----------------------------------------------------------------------------------------|---------------|
| Parte V — Cierre académico | 19–23 (resultados, conclusiones, recomendaciones, referencias, cobertura de la rúbrica) | Informe Final |
| Anexos                     | A–J                                                                                     | Soporte       |

## Índice de evidencias

| ID           | Evidencia                                                                         | Archivo (en docs/evidencias/)                                                                                                            | Estado                       |
|--------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| EV-C204-001  | Versiones del entorno: node v20.20.2, npm 10.8.2 en el Codespace                  | capturas/consola-git/EV-C204-046-screenshot-image4.png                                                                                   | ✓ (Docker: ver EV-C204-001b) |
| EV-C204-001b | Versión de Docker en el Codespace corregido: Docker version 29.8.1, build 4a63305 | capturas/EV-C204-001b-docker-version.png                                                                                                 | ✓                            |
| EV-C204-002  | Servicio /salud respondiendo en el Codespace                                      | capturas/EV-C204-002-salud.jpeg y resumen EV-C204-002b-resumen-chatgpt.png (+ transcripción: EV-C204-023-pruebas-e2e-keycloak.txt, P-09) | ✓                            |
| EV-C204-003  | Keycloak: realm appmovil (consola web del Codespace)                              | capturas/EV-C204-003-realm.jpeg (+ datos: EV-C204-023-pruebas-e2e-keycloak.txt)                                                          | ✓                            |
| EV-C204-004  | Keycloak: cliente servicio-cifrado (consola web del Codespace)                    | capturas/EV-C204-004-cliente.png (+ datos, ídem)                                                                                         | ✓                            |
| EV-C204-005  | Keycloak: usuario demo (consola web del Codespace)                                | capturas/EV-C204-005-usuario.png (+ datos: EV-C204-023-pruebas-e2e-keycloak.txt)                                                         | ✓                            |
| EV-C204-006  | App móvil cifrando/descifrando en el Codespace                                    | capturas/EV-C204-006-app.png                                                                                                             | ✓                            |
| EV-C204-     | Pipeline Fase 1 (jobs en                                                          | capturas/consola-git/                                                                                                                    | ✓                            |

| ID                | Evidencia                                                               | Archivo (en docs/evidencias/)                                                        | Estado |
|-------------------|-------------------------------------------------------------------------|--------------------------------------------------------------------------------------|--------|
| 007               | rojo)                                                                   | EV-C204-047...051, 033...036 (ver §13 y Anexo I)                                     |        |
| EV-C204-008       | Reporte Semgrep del <b>run verde</b> (Fase 2)                           | capturas/EV-C204-008-semgrep.json                                                    | ✓      |
| EV-C204-009       | Reporte Gitleaks del <b>run verde</b> (Fase 2)                          | capturas/EV-C204-009-gitleaks.json                                                   | ✓      |
| EV-C204-010       | SBOM del <b>run verde</b> (Fase 2)                                      | capturas/EV-C204-010-sbom.json                                                       | ✓      |
| EV-C204-011       | Informe ZAP del <b>run verde</b> (Fase 2)                               | capturas/EV-C204-011-zap.html                                                        | ✓      |
| EV-C204-012       | Alertas CodeQL (Code scanning): 0 abiertas, 3 cerradas                  | capturas/EV-C204-012-codeql-alertas.png (+ datos: EV-C204-025-codeql-alertas.json)   | ✓      |
| EV-C204-013       | Pipeline Fase 2 (todo verde), run #27 (35442482331)                     | capturas/EV-C204-013-pipeline-verde.png (+ transcripción: EV-C204-026-run-verde.txt) | ✓      |
| EV-C204-014       | Rama main protegida (ruleset proteger-main)                             | capturas/EV-C204-014-proteccion.png (+ configuración: EV-C204-030-ruleset-main.json) | ✓      |
| EV-C204-015       | Figura 1. Contexto de la aplicación                                     | figuras/figura-1-contexto.svg                                                        | ✓      |
| EV-C204-016       | Figura 2. Arquitectura y límites de confianza                           | figuras/figura-2-arquitectura.svg                                                    | ✓      |
| EV-C204-017       | Figura 3. Flujo de cifrado con identidad                                | figuras/figura-3-flujo.svg                                                           | ✓      |
| EV-C204-018 / 019 | Capturas de consola del equipo (PPTX y PDF originales)                  | capturas/EV-C204-018-...pptx, EV-C204-019-...pdf                                     | ✓      |
| EV-C204-020       | Archivo generado reporte-gitleaks de la <b>Fase 1</b> (run 35365578175) | capturas/EV-C204-020-reporte-gitleaks.zip                                            | ✓      |

| ID                     | Evidencia                                                             | Archivo (en docs/evidencias/)                 | Estado |
|------------------------|-----------------------------------------------------------------------|-----------------------------------------------|--------|
| EV-C204-021            | Archivo generado<br>reporte-semgrep de la <b>Fase 1</b>               | capturas/EV-C204-021-report-semgrep.zip       | ✓      |
| EV-C204-022            | Archivo generado<br>reporte-zap de la <b>Fase 1</b>                   | capturas/EV-C204-022-report-zap.zip           | ✓      |
| EV-C204-023            | Pruebas extremo a extremo con Keycloak real (25 comprobaciones)       | capturas/EV-C204-023-pruebas-e2e-keycloak.txt | ✓      |
| EV-C204-024            | Pruebas Jest (22), ESLint y npm audit                                 | capturas/EV-C204-024-pruebas-unitarias.txt    | ✓      |
| EV-C204-025            | Alertas y análisis de CodeQL                                          | capturas/EV-C204-025-codeql-alertas.json      | ✓      |
| EV-C204-026            | Run verde de referencia (jobs, archivos generados, CodeQL)            | capturas/EV-C204-026-run-verde.txt            | ✓      |
| EV-C204-027            | SBOM de la <b>Fase 1</b> (comprimido)                                 | capturas/EV-C204-027-sbom-fase1.zip           | ✓      |
| EV-C204-028            | Log de los jobs en rojo de la Fase 1 (secretos redactados)            | capturas/EV-C204-028-log-fase1-jobs-rojos.txt | ✓      |
| EV-C204-029            | Historial de las 22+ ejecuciones del pipeline                         | capturas/EV-C204-029-historial-runs.txt       | ✓      |
| EV-C204-033 ...<br>051 | 19 capturas de pantalla del equipo, individualizadas                  | capturas/consola-git/(Anexo I)                | ✓      |
| EV-C204-030            | Configuración real del ruleset proteger-main (API de GitHub)          | capturas/EV-C204-030-ruleset-main.json        | ✓      |
| EV-C204-031            | Contribuidores del repositorio (Insights → Contributors, 19-sep-2026) | capturas/EV-C204-031-contribuidores.png       | ✓      |
| EV-C204-               | Copias del PPTX y PDF                                                 | capturas/consola-git/                         | ✓      |

| ID        | Evidencia              | Archivo (en docs/evidencias/) | Estado                    |
|-----------|------------------------|-------------------------------|---------------------------|
| 052 / 053 | dentro de consola-git/ |                               | (duplicados de 018 y 019) |

## PARTE I — CONTEXTO Y DISEÑO

### 1. Introducción

El presente proyecto desarrolla un **pipeline DevSecOps completo** para una aplicación móvil de cifrado de datos. La aplicación móvil actúa como cliente; el cifrado ocurre en un servicio backend desarrollado en **Node.js**; la identidad de los usuarios la gestiona **Keycloak** (IAM); y un pipeline de **GitHub Actions** ejecuta seis pruebas de seguridad automáticas en cada cambio del código.

La característica distintiva del laboratorio es que el proyecto **arranca inseguro a propósito**: contiene errores de seguridad reales (secretos quemados, dependencias vulnerables, validación deficiente de tokens, CORS abierto, entre otros), marcados en el código con comentarios `// [VULN-n]`. El pipeline los detecta automáticamente y el trabajo del estudiante consiste en corregirlos uno por uno hasta dejar todas las pruebas en verde.

La metodología sigue el ciclo **DevSecOps**: *detectar* → *corregir* → *volver a probar*. En la **Fase 1 (Diagnóstico)** se sube el proyecto tal cual y se documentan todos los hallazgos en rojo; en la **Fase 2 (Remediación)** se corrige cada error, se sube el cambio y se verifica la transición de rojo a verde. Este ciclo automatizado es el valor central del laboratorio: no basta con encontrar los errores, sino que el proceso garantiza que las correcciones se verifican de forma reproducible.

El marco de referencia del proyecto combina **NIST SSDF** (Secure Software Development Framework) para las prácticas del ciclo de vida seguro, **OWASP SAMM** para la madurez del proceso, **OWASP ASVS** y **OWASP MASVS** para los requisitos de seguridad verificables, y **STRIDE** para el modelado de amenazas.

## 2. Objetivos

### 2.1 Objetivo general

Implementar un pipeline DevSecOps completo para una aplicación móvil de cifrado —desde el análisis de requerimientos y el modelado de amenazas hasta el diagnóstico automatizado de vulnerabilidades y su remediación verificada—, dejando el pipeline en verde y documentando todo el proceso con evidencia.

### 2.2 Objetivos específicos

1. **Analizar los requerimientos de seguridad** de la aplicación móvil (confidencialidad, integridad, disponibilidad y autenticación), justificando cada uno y mapeándolos a estándares (OWASP SAMM, NIST SSDF, ASVS, MASVS).
2. **Modelar las amenazas** del sistema con STRIDE, identificando componente afectado, ejemplo de ataque, control y severidad por amenaza.
3. **Configurar el entorno de desarrollo en la nube** (GitHub Codespaces) con Node.js 20 y Docker, documentando la configuración paso a paso.
4. **Implementar el módulo de cifrado RSA** (padding OAEP) en el servicio backend, con funciones de utilidad de validación de entrada y manejo de errores.
5. **Configurar la identidad** con Keycloak (realm, cliente y usuario) y verificar el flujo completo de cifrado/descifrado con token.
6. **Ejecutar el pipeline de seis pruebas de seguridad** (SAST ×2, secretos, SCA, imagen y DAST) y documentar los hallazgos de la Fase 1.
7. **Corregir las vulnerabilidades** en la Fase 2, verificando la transición de rojo a verde con trazabilidad por commit.
8. **Calcular los riesgos** de las vulnerabilidades con método probabilístico ( $P \times I$ ) y análisis gerencial (ALE).
9. **Documentar todas las pruebas** realizadas (funcionales, del pipeline, pentest y automatizadas) con datos de entrada, esperado y real.
10. **Proteger la rama principal** y entregar el informe integrado en PDF con todas las tablas consolidadas.

## 3. Alcance, supuestos y reglas de compromiso

### 3.1 Alcance

- **App móvil (cliente):** aplicación Expo/React Native que cifra y descifra datos y maneja el token.

- **Servicio de cifrado (backend):** API Node.js con endpoints /salud, /cifrar y /descifrar, módulo RSA y validación de token.
- **IAM:** Keycloak que entrega y valida tokens JWT.
- **Pipeline DevSecOps:** seis pruebas automáticas en GitHub Actions.
- **Documentación:** informe integrado, tablas 1–6, evidencias y plantilla de diagnóstico.

### 3.2 Supuestos

- El entorno de desarrollo es **GitHub Codespaces** (imagen Node 20); el pipeline corre en GitHub Actions (ubuntu-latest).
- El repositorio se mantuvo **privado durante el desarrollo inicial** (así se ve en las capturas de la Fase 1) y hoy es **público**, requisito para que CodeQL sea gratuito y el docente pueda revisarlo.
- Los secretos del laboratorio son **ficticios, de práctica** (la llave AWS es la de ejemplo de la documentación de AWS); no se subieron secretos reales.
- **CodeQL** corre mediante el *default setup* de GitHub y no como job del workflow (ver §8.6 y §12.1): son mutuamente excluyentes en el mismo repositorio.
- Las pruebas funcionales con identidad se ejecutaron contra un **Keycloak 24.0 en Docker local**; la verificación en el Codespace se realizó sobre la consola de Keycloak y la aplicación móvil (EV-C204-003 a 006).

### 3.3 Reglas de compromiso

- **Permitido:** ejecutar el laboratorio en el Codespace, generar y eliminar llaves de prueba, cifrar/descifrar datos de demostración, ejecutar el pipeline y descargar reportes.
- **Prohibido:** usar llaves o credenciales reales, subir secretos al repositorio, ejecutar el pentest contra sistemas de terceros, publicar el repositorio con datos sensibles.

## 4. Metodología

### 4.1 Ciclo DevSecOps

El proyecto sigue el ciclo **detectar → corregir → volver a probar**:

1. **Fase 1 — Diagnóstico:** se sube el proyecto inseguro, el pipeline se ejecuta solo y se documentan todos los hallazgos en rojo (Tabla 3).
2. **Fase 2 — Remediación:** se corrige cada hallazgo (un commit por corrección), se sube el cambio y se verifica la transición a verde (Tabla 4).

3. **Cierre:** pentest, cálculo de riesgos (Tabla 5), documentación de pruebas (Tabla 6), protección de la rama principal e informe final.

## 4.2 Marco de referencia

| Marco                         | Aporte al proyecto                                                                                                    |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>NIST SSDF</b> (SP 800-218) | Prácticas del ciclo de vida seguro: definir requisitos (PW.4), implementar código seguro (PW.5–7), verificar (RV.1–3) |
| <b>OWASP SAMM</b>             | Madurez del proceso DevSecOps: estrategia, diseño seguro, implementación, verificación, operaciones                   |
| <b>OWASP ASVS</b>             | Requisitos de seguridad verificables (autenticación, validación, criptografía, errores, cabeceras)                    |
| <b>OWASP MASVS</b>            | Requisitos específicos de aplicaciones móviles                                                                        |
| <b>STRIDE</b> (Microsoft)     | Modelado de amenazas por categoría                                                                                    |
| <b>CWE</b>                    | Identificación precisa de debilidades en los hallazgos                                                                |

## 4.3 Reproducibilidad

Todo el entorno es reproducible: `.devcontainer/devcontainer.json` define el Codespace (Node 20 + Docker); `docker-compose.yml` define el stack (servicio + Keycloak); el pipeline se ejecuta en cada push. Los reportes se descargan como archivos generados y se registran con hash SHA-256 en el manifiesto de evidencias.

## 5. Requerimientos de seguridad

Ver **Tabla 1** completa en docs/tablas/tabla-1-requisitos.md

| Propiedad        | Requisito                           | Control                                         | Verificación                                |
|------------------|-------------------------------------|-------------------------------------------------|---------------------------------------------|
| Confidencialidad | Los datos se cifran antes de viajar | RSA-2048 OAEP-SHA256 en <code>cifrado.js</code> | Roundtrip cifrar/descifrar; DAST            |
| Integridad       | Un dato alterado no se descifra     | OAEP detecta manipulación; fallo seguro         | Pentest: 1 byte alterado → error controlado |

| Propiedad                   | Requisito                                | Control                                                                                                  | Verificación                                                                                  |
|-----------------------------|------------------------------------------|----------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Disponibilidad              | El servicio no se cae con entradas raras | Validación de tipo y tamaño (190 bytes UTF-8, cuerpo $\leq 10$ KB) y límite de 100 peticiones/min por IP | Entrada vacía / 191 B / 20 KB / no texto → rechazo (P-06 a P-08); 130 peticiones → 429 (P-21) |
| Autenticación               | Solo usuarios válidos usan el servicio   | JWT de Keycloak verificado en <code>auth.js</code> (RS256, JWKS del realm, exp, azp/aud)                 | /cifrar sin token → 401; con token real de Keycloak → 200 (P-03, P-04)                        |
| No repudio ( <i>extra</i> ) | Toda operación queda registrada          | Línea JSON por operación (usuario, acción, resultado, IP) en la salida del servicio                      | P-24: la operación aparece y el texto plano no                                                |

**Justificación:** cada requisito se justifica en la Tabla 1 (por qué es necesario, qué ataque mitiga y qué estándar lo respalda). La justificación cubre: confidencialidad (red no confiable), integridad (manipulación en tránsito), disponibilidad (DoS por entrada malformada), autenticación (abuso del servicio como oráculo de cifrado) y no repudio (auditoría).

## 6. Amenazas (STRIDE)

Ver **Tabla 2** completa en `docs/tablas/tabla-2-stride.md`

| Amenaza                | Componente        | Ejemplo de ataque                | Control                         | Severidad |
|------------------------|-------------------|----------------------------------|---------------------------------|-----------|
| Spoofing               | API de cifrado    | Usar el servicio sin identidad   | JWT válido (Keycloak)           | Alta      |
| Tampering              | Datos en tránsito | Alterar el texto cifrado         | Descifrado que falla seguro     | Alta      |
| Repudiation            | Servicio          | Negar una operación              | Bitácora y logs                 | Media     |
| Information disclosure | Servicio / repo   | Leer secretos o errores internos | Sin secretos; errores genéricos | Alta      |
| Denial of service      | API de cifrado    | Enviar datos enormes             | Límite de tamaño de entrada     | Media     |
| Elevation of           | Contenedor        | Ejecutar como root               | Contenedor no-                  | Media     |

| Amenaza   | Componente | Ejemplo de ataque | Control | Severidad |
|-----------|------------|-------------------|---------|-----------|
| privilege | r          |                   | root    |           |

Cada amenaza incluye en la Tabla 2: severidad justificada, prueba concreta de verificación del control y CWE asociada (para cruzar con los hallazgos de la Tabla 3).

## 6.1 Casos de abuso (misuse cases)

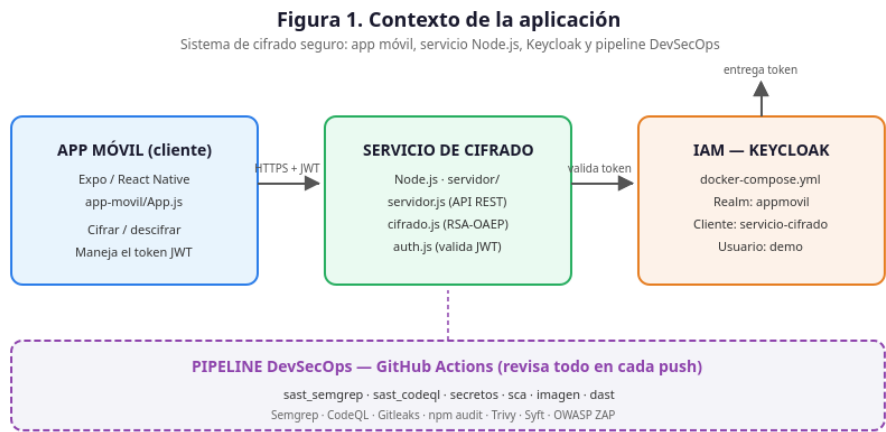
Complementan el modelado STRIDE con escenarios concretos de uso malicioso:

| ID    | Caso de abuso                                           | Actor                     | Resultado esperado del control               |
|-------|---------------------------------------------------------|---------------------------|----------------------------------------------|
| CA-01 | Usar el servicio de cifrado sin autenticarse            | Atacante externo          | 401 No autorizado                            |
| CA-02 | Cifrar/descifrar con un token falso (firma inválida)    | Atacante externo          | 401 No autorizado                            |
| CA-03 | Alterar el texto cifrado en tránsito                    | Atacante MITM             | Error controlado (OAEP detecta manipulación) |
| CA-04 | Enviar entradas malformadas (vacías, enormes, no texto) | Atacante externo          | Rechazo con 400; servicio sigue disponible   |
| CA-05 | Leer secretos del repositorio                           | Cualquiera (repo público) | Sin secretos en el repo (Gitleaks en verde)  |
| CA-06 | Explotar el servicio como oráculo de cifrado            | Atacante autenticado      | Rate limiting y bitácora (no repudio)        |
| CA-07 | Escalar privilegios dentro del contenedor               | Atacante con acceso       | Contenedor no-root (Trivy en verde)          |
| CA-08 | Negar una operación realizada                           | Usuario                   | Bitácora consultable (no repudio)            |

## 7. Jerarquía de diseño

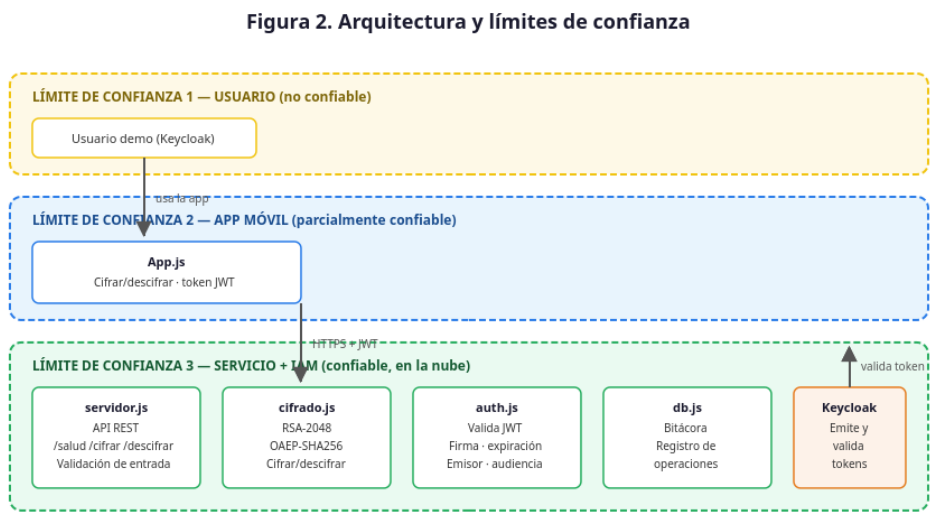
Ver docs/jerarquia\_diseno.md — arquitectura, árbol de archivos, tabla de subsistemas y componentes críticos.

**Figura 1. Contexto de la aplicación (EV-C204-015):** la app móvil consume el servicio de cifrado (RSA), Keycloak valida la identidad y el pipeline DevSecOps revisa todo en cada cambio.



*Figura 1 (EV-C204-015)*

**Figura 2. Arquitectura y límites de confianza (EV-C204-016):** las tres capas (app, servicio, IAM) con sus límites de confianza.



*Figura 2 (EV-C204-016)*

**Figura 3. Flujo de cifrado con identidad (EV-C204-017):** la app pide un token a Keycloak, lo envía al servicio, y este valida el token antes de cifrar/descifrar con RSA.

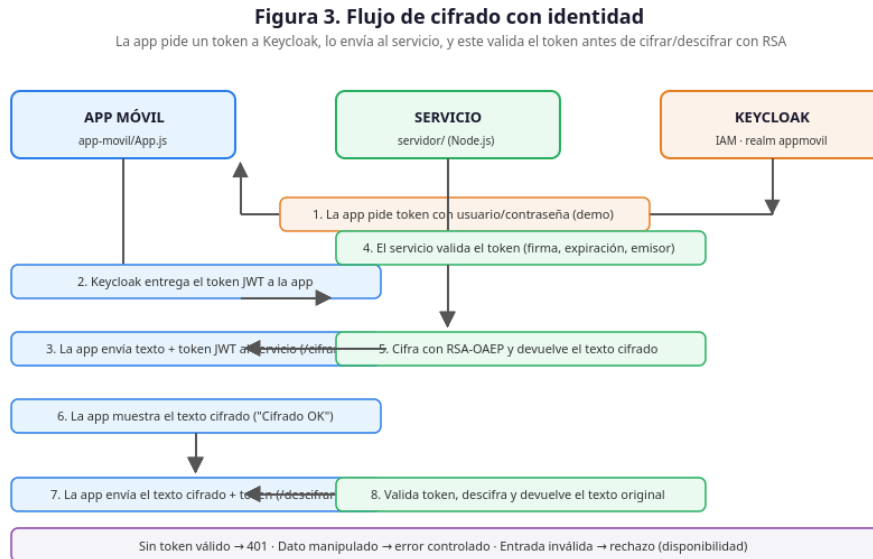


Figura 3 (EV-C204-017)

## 7.1 Subsistemas

| Subsistema     | Función                               | Superficie de ataque | Propensión a fallar |
|----------------|---------------------------------------|----------------------|---------------------|
| App móvil      | Cifrar/descifrar; maneja el token     | Alta                 | Media               |
| API de cifrado | Endpoints /salud, /cifrar, /descifrar | <b>Alta</b>          | <b>Alta</b>         |
| Módulo RSA     | Cifrado/descifrado RSA-OAEP           | Media                | Media               |
| Autenticación  | Valida token JWT                      | <b>Alta</b>          | <b>Alta</b>         |
| Bitácora       | Registra operaciones                  | Media                | Media               |
| IAM (Keycloak) | Entrega y valida tokens               | <b>Alta</b>          | Media               |
| Pipeline       | Pruebas de seguridad                  | Baja                 | Baja                |

## 7.2 Componentes críticos

Según los cuatro factores de la rúbrica (complejidad, frecuencia de uso, exposición a datos sensibles e interacción con componentes externos), los componentes críticos son: **API de cifrado, autenticación (JWT), módulo RSA y app móvil**. Sus modos de fallo y mitigaciones están documentados en docs/jerarquia\_diseno.md.

### 7.3 Inventario de activos

| ID   | Activo                                               | Tipo          | Clasificación          | Dueño         | Almacenamiento                                                                                 |
|------|------------------------------------------------------|---------------|------------------------|---------------|------------------------------------------------------------------------------------------------|
| A-01 | Texto plano del usuario                              | Datos         | Confidencial           | Usuario       | En memoria, solo durante la operación                                                          |
| A-02 | Texto cifrado (base64)                               | Datos         | Confidencial           | Usuario       | En memoria / respuesta HTTP                                                                    |
| A-03 | Llaves RSA (pública/privada)                         | Criptográfico | <b>Crítico</b>         | Servicio      | Solo en la memoria del servicio: se generan al arrancar y no se guardan en disco ni en el repo |
| A-04 | Tokens JWT                                           | Credencial    | <b>Crítico</b>         | Usuario       | En memoria de la app                                                                           |
| A-05 | Credenciales de Keycloak (admin/demo)                | Credencial    | <b>Crítico</b>         | Administrador | Consola Keycloak / env                                                                         |
| A-06 | Bitácora de operaciones                              | Datos         | Confidencial           | Servicio      | Salida estándar del servicio (JSON); consulta parametrizada a MySQL en db.js (/buscar)         |
| A-07 | Código fuente (servidor + app)                       | Código        | Público (al finalizar) | Equipo        | Repositorio GitHub                                                                             |
| A-08 | Reportes de seguridad (Semgrep, Gitleaks, SBOM, ZAP) | Evidencia     | Confidencial           | Equipo        | docs/evidencias/ + archivos generados                                                          |

El inventario alimenta el análisis ALE de la Tabla 5 (valor de activos y factor de exposición).

## 8. Configuración del entorno (paso a paso)

### 8.1 Entorno en la nube (Codespace)

1. Crear el repositorio proyecto-devsecops-cib204 (se creó privado y hoy es público).
2. Abrir un Codespace en el repositorio (máquina 2-core). La configuración vive en `.devcontainer/devcontainer.json` (imagen `javascript-node:20`, puertos 3000, 8080 y 8081 reenviados).
3. Verificar las versiones:

```
node --version      # v20.x
npm --version        # 10.x
```

Resultado real en el Codespace del equipo: node v20.20.2 y npm 10.8.2 (EV-C204-046).

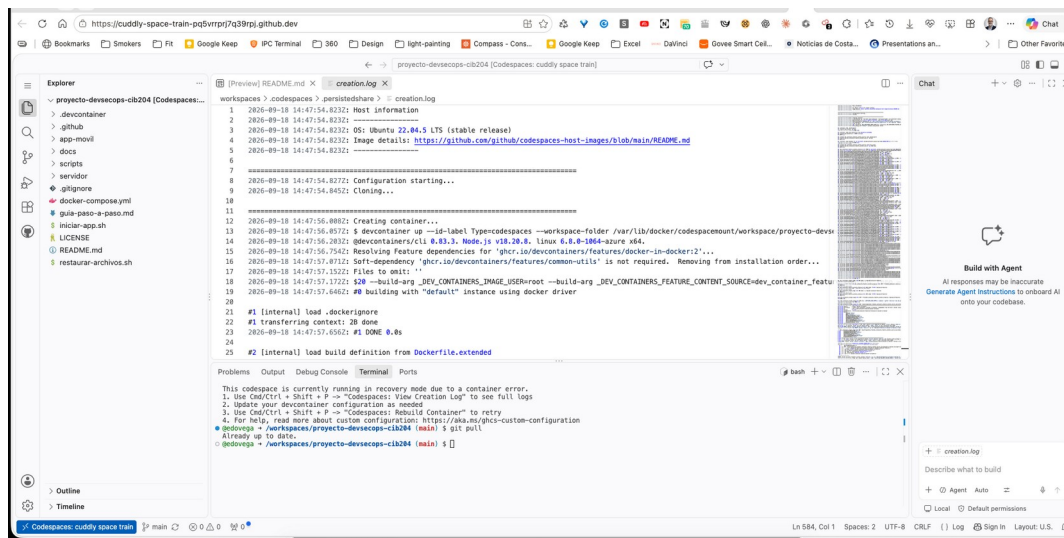
**Incidente del Codespace (detalle en `reporte-docente-devcontainer.md`).** El `.devcontainer/devcontainer.json` del **zip oficial** usa la imagen `mcr.microsoft.com/devcontainers/javascript-node:20` más la característica `docker-in-docker:2` (sin opciones). Al abrir el Codespace, este arrancaba en **modo de recuperación** («This codespace is currently running in recovery mode due to a container error», EV-C204-043 y EV-C204-044). El commit 46cb634 retiró la característica y el Codespace pasó a arrancar en menos de un minuto (EV-C204-045).

*Causa (confirmada para la variante con `docker-outside-of-docker`, inferida para la del zip).* Al reproducir el fallo con la configuración alternativa, el registro de creación del Codespace muestra: The 'moby' option is not supported on debian 'trixie' because 'moby-cli' and related system packages are not available in that distribution y Feature "Docker (docker-outside-of-docker)" failed to install. La imagen `javascript-node:20` es hoy **Debian 13 «trixie»** (verificado: `PRETTY_NAME="Debian GNU/Linux 13 (trixie)"`), Node 20.20.2, igual que la captura EV-C204-046) y las características de Docker instalan por defecto el paquete `moby`, que no existe en `trixie`. La característica `docker-in-docker:2` del zip tiene la misma opción por defecto y la misma imagen base, por lo que es **muy probable** que la causa sea la misma; no se conservó el texto exacto del error de la configuración original, solo su síntoma (modo de recuperación). Nota: una versión anterior de este informe atribuía el fallo al plan gratuito de 2 núcleos; esa hipótesis no tiene respaldo en los registros y se descarta.

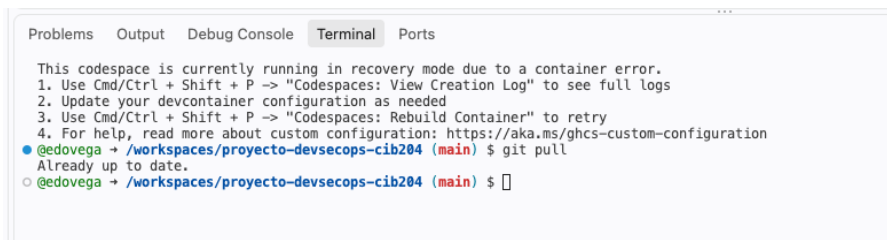
*Reporte a la docente.* El incidente fue reportado a la docente el 19 de septiembre de 2026 (reporte-docente-devcontainer.md). Según lo comunicado por el estudiante, la docente indicó que no había experimentado el error, el cual podría obedecer a diferencias en el tipo de cuenta de GitHub, consideró correcto el reporte y aprobó la modificación propuesta al devcontainer.json. La respuesta fue verbal y no se adjunta constancia escrita; la hipótesis sobre el tipo de cuenta no ha sido verificada.

*Solución.* La configuración alternativa

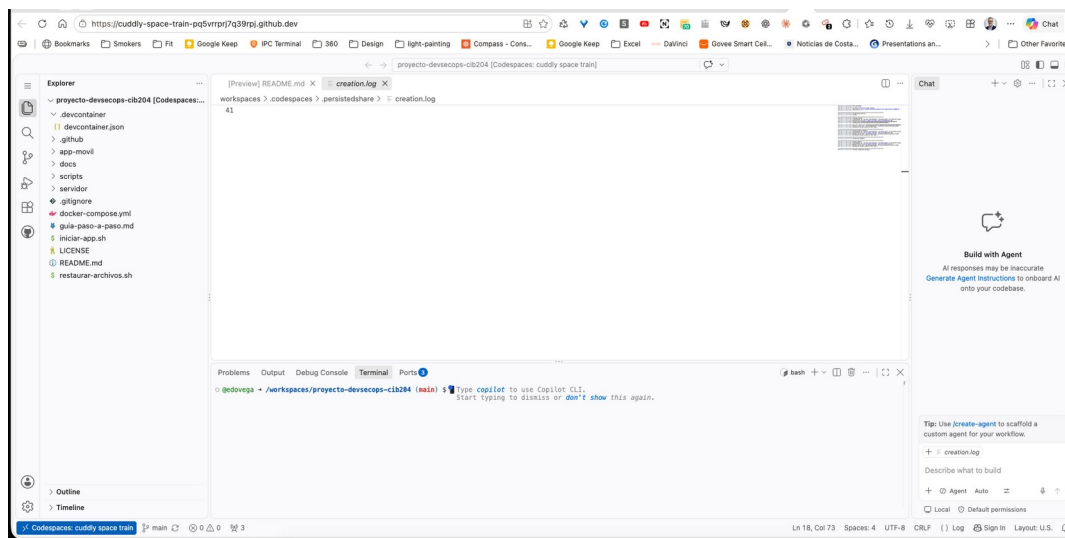
.devcontainer/con-docker/devcontainer.json usa docker-outside-of-docker con "moby": false, que es lo que indica el propio mensaje de error (usar el Docker CLI de Docker en lugar de moby).



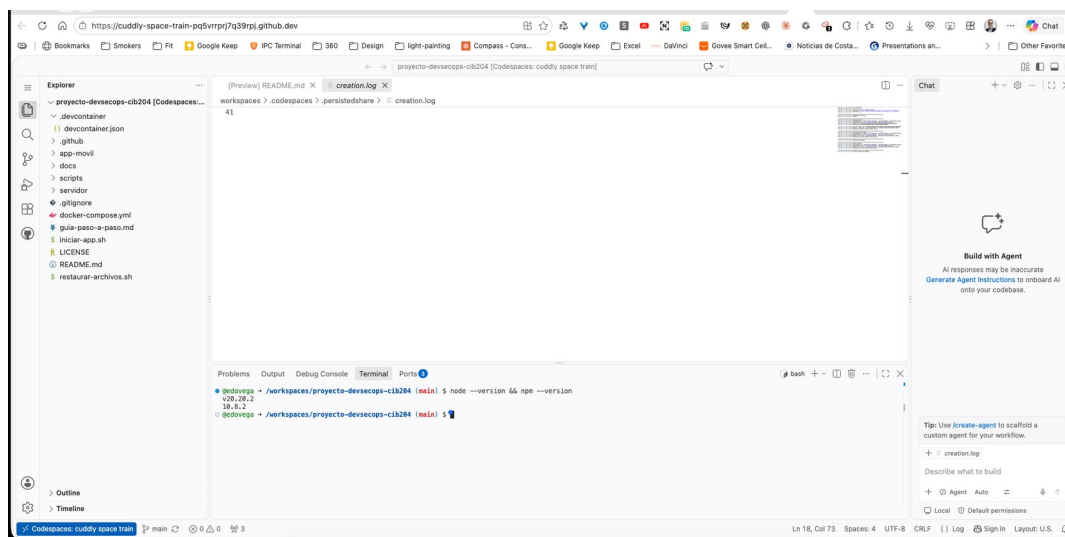
*EV-C204-043 — Registro de creación del Codespace (creation.log) y mensaje de modo de recuperación*



*EV-C204-044 — Detalle del terminal: modo de recuperación y git pull («Already up to date»)*

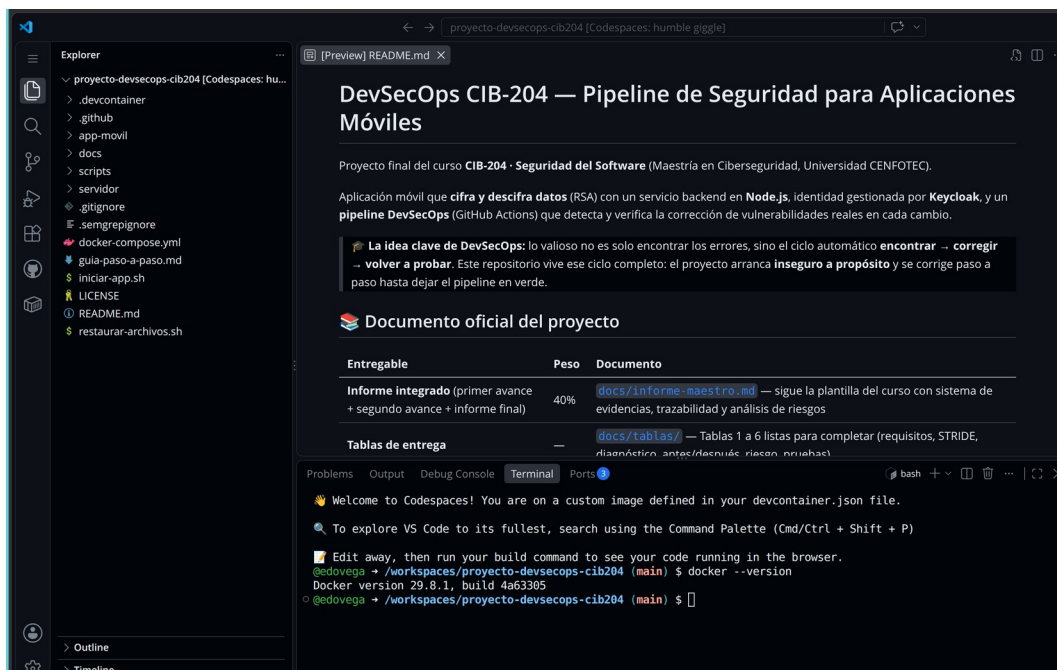


*EV-C204-045 — Codespace ya operativo: explorador con .devcontainer, .github, app-movil, docs, scripts, servidor*



*EV-C204-046 — Versiones reales del entorno: node v20.20.2 y npm 10.8.2*

**Docker en el Codespace:** la configuración por defecto (sin Docker) no permite los pasos 6.2 y 7 de la guía (docker compose up, Keycloak). Para eso se creó la configuración alternativa con-docker (*Code* → *Codespaces* → *New with options...* → *CIB-204 DevSecOps (Node 20 + Docker)*) con "moby": false; fue probada por el equipo: en su Codespace la consola de Keycloak (contenedor Docker) responde en el puerto 8080 y el servicio en el 3000 (EV-C204-005 y EV-C204-006), y docker --version devuelve Docker version 29.8.1, build 4a63305 (EV-C204-001b, Codespace «humble giggle», 19-sep-2026). El pipeline de GitHub Actions no depende de esto.



EV-C204-001b — Codespace corregido con Docker: `docker --version` → Docker version 29.8.1, build 4a63305

**Evidencia:** EV-C204-043 a EV-C204-046 (EV-C204-001 = 046) y EV-C204-001b (Docker).

## 8.2 Levantar el servicio y Keycloak

```
docker compose up -d --build
docker compose ps      # ambos "running"
```

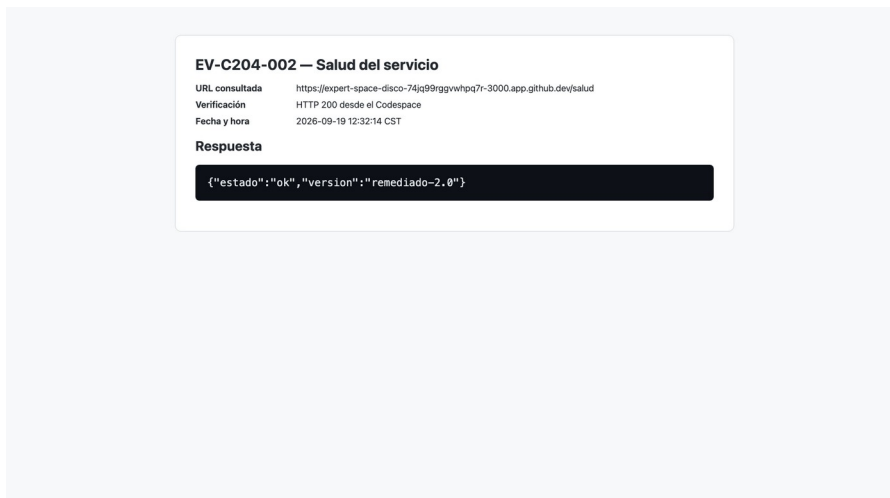
El servicio responde en el puerto 3000; Keycloak en el 8080. Verificación: abrir la URL del puerto 3000 con `/salud`. La versión insegura de la Fase 1 respondía `{"estado": "ok", "version": "inseguro-1.0"}`; la versión remediada responde `{"estado": "ok", "version": "remediado-2.0"}` (P-09, EV-C204-023).

El `docker-compose.yml` arranca con el control de acceso **apagado** (`AUTH_ENABLED=false`) para el primer ensayo; se activa con `AUTH_ENABLED=true` (sección 8.3).

**Evidencia:** EV-C204-002 (captura del navegador en el Codespace; transcripción de la misma prueba en EV-C204-023).

```
Pretty-print ☐  
{\"estado\":\"ok\",\"version\":\"remediado-2.0\"}
```

*EV-C204-002 — Respuesta de /salud en el Codespace:*  
`{\"estado\":\"ok\", \"version\":\"remediado-2.0\"}`



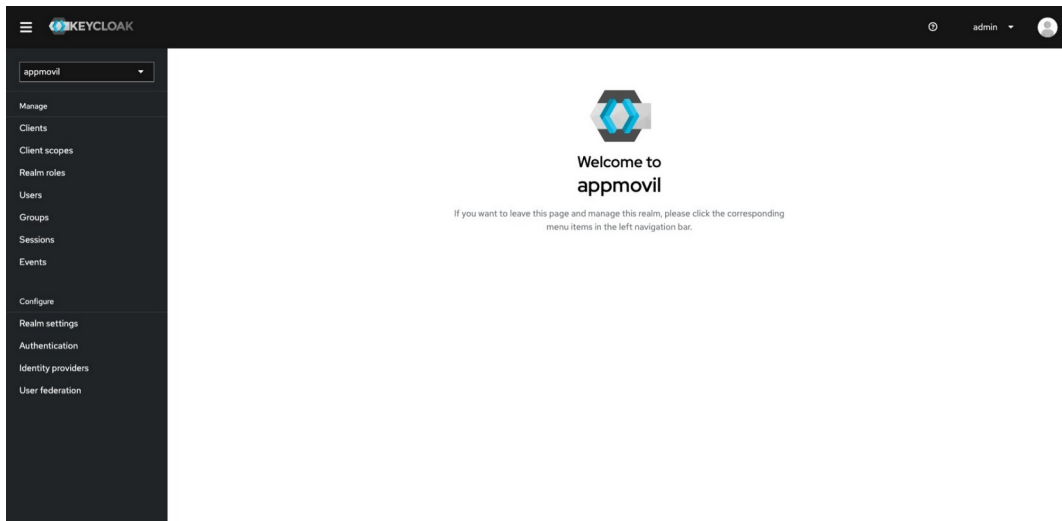
*EV-C204-002b — Resumen de la misma consulta elaborado por el asistente de navegador (ChatGPT): URL, HTTP 200 y hora (12:32 CST). **No es una captura directa del navegador**; la evidencia principal es la imagen anterior*

### 8.3 Configurar Keycloak (IAM)

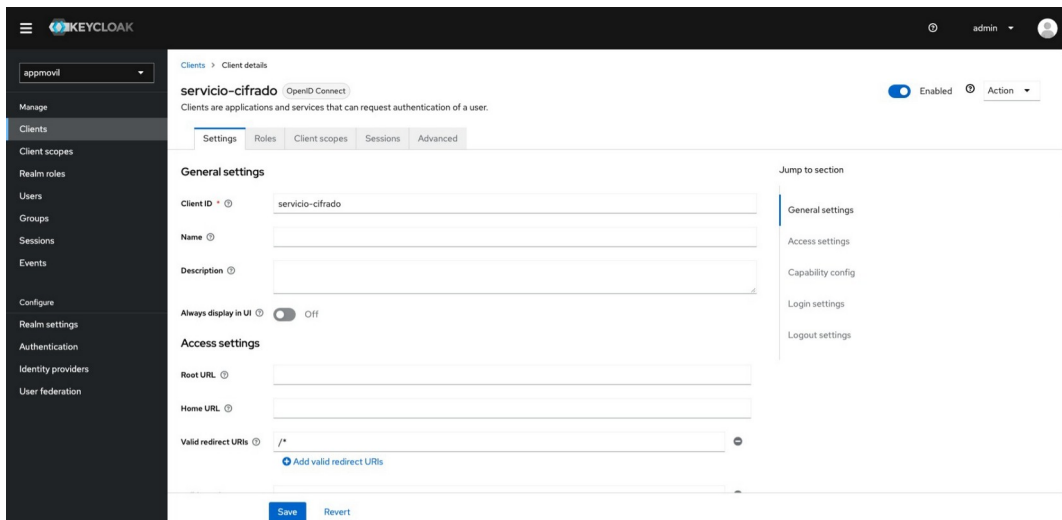
1. Abrir la consola de administración (puerto 8080).
2. Crear el realm appmovil.
3. Crear el cliente servicio-cifrado (OpenID Connect, *Direct access grants*).
4. Crear el usuario demo (email, nombre, apellido, email verificado, contraseña no temporal).
5. Activar AUTH\_ENABLED=true en el servicio: a partir de ese momento /cifrar, /descifrar y /buscar exigen un token de Keycloak.

**Verificación real.** Estos cuatro pasos se ejecutaron por la API de administración de un **Keycloak 24.0 real** (realm → HTTP 201, cliente → 201, usuario → 201), se obtuvo un token RS256 con el usuario demo y se probó el servicio completo con él (25 comprobaciones, todas correctas; ver §11.3). Fuente: EV-C204-023.

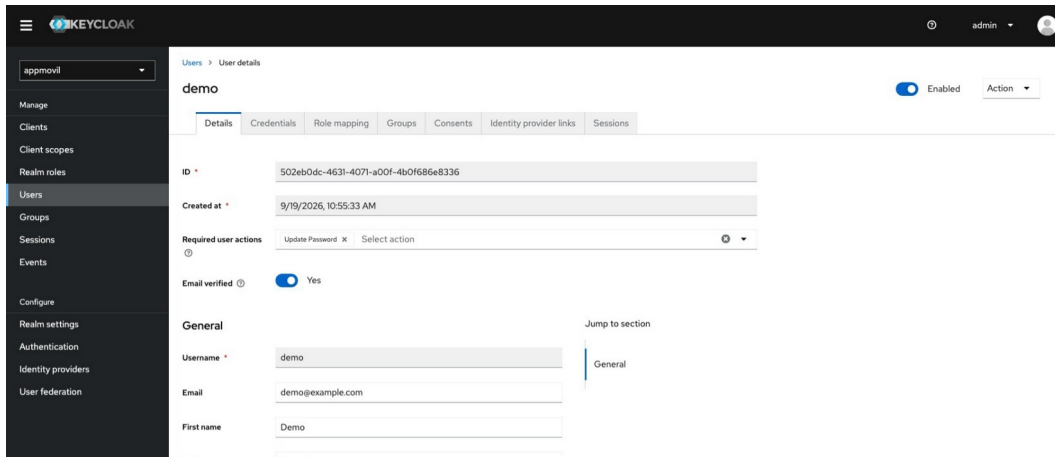
**Evidencia:** EV-C204-003 a EV-C204-005 (capturas de la consola web de Keycloak en el Codespace) y, además, por API (EV-C204-023).



*EV-C204-003 — Consola de Keycloak: realm appmovil («Welcome to appmovil»)*



*EV-C204-004 — Cliente servicio-cifrado (OpenID Connect, habilitado)*



*EV-C204-005 — Consola de Keycloak en el Codespace: realm appmovil, usuario demo habilitado, email verificado, creado el 19-sep-2026*

**Nota técnica:** el usuario demo conserva la acción requerida «Update Password», por lo que no puede obtener un token por contraseña directa hasta retirarla (ver P-28 en la Tabla 6).

## 8.4 Probar la app móvil

```
bash iniciar-app.sh # entra a app-movil/, instala y arranca Expo (puerto 8081)
```

El puerto 3000 debe estar en **Público** (Port Visibility → Public) para que la app pueda llamar al servicio; **al terminar la prueba debe volver a Privado o eliminarse el Codespace**. Además, la app corre en otro origen (puerto 8081), por lo que el servicio debe permitirlo mediante CORS: el docker-compose.yml define ORIGENES\_PERMITIDOS (localhost y, en Codespaces, la URL del puerto 8081 armada con CODESPACE\_NAME). En la app: pegar la URL del puerto 3000, pegar el **token** (solo el valor de access\_token, sin la palabra «Bearer»: la app la antepone), escribir un texto, pulsar «Cifrar» y luego «Descifrar». Si el texto pasa de 190 bytes el servicio responde 400.

**Evidencia:** EV-C204-006. La app se ejecutó en el Codespace del equipo con el acceso apagado (sin token): cifró «Hola CIB-204» y lo descifró de vuelta («Estado: Descifrado OK»). Se probó la app **sin** identidad; el flujo con token de Keycloak se probó por separado en las 25 comprobaciones de EV-C204-023.

**Configuración de CORS para la app móvil.** La app se sirve desde el puerto 8081, origen distinto del servicio (puerto 3000), que solo permitía http://localhost:3000. Para la prueba en el Codespace se agregó localmente la URL del puerto 8081 en servidor/config.js; el cambio no se versionó porque fija una dirección propia de cada Codespace. Se sustituyó por la variable

ORIGENES\_PERMITIDOS en docker-compose.yml, verificada con un origen permitido (recibe Access-Control-Allow-Origin) y uno ajeno (no la recibe). La lista blanca se mantiene: no se abre a \*.

Ciente movil - Cifrado CIB-204

URL del servicio

https://expert-space-disco-74jqd9rggwhtpq7r-3000.app.github.dev

Token (opcional, si el IAM esta activo)

Bearer...

Texto a cifrar

Hola CIB-204

Cifrar

Cifrado (resultado)

c2G6SP2H5Mzbh2j4duae4PN76bhnyIIRPHNBbEtIVDpCO058u49zEJN3LENP023qPuvvHXzDVcBmh3mO2JZW7RBH8Eu1tHTUPhOZmFXKjKa3Y57AYAY5waCXLABN6PRlqYUTN+QKxZYUSi44buC6H10VfwQZan7/9e4NnHVu3DKmoBs9RPZesKnoar5yb0073kUd4Kp2L+zzftvNPH4JhYdoCySuFrmqJT+IEYISpibG7TqTQwkJKk4+5KfNpFpRYM926uJH+Oip8fUSYct8eFse89QhoZWH3edto2dQzrxDEELpPnqZWTeDw==

Descifrar

Descifrado (resultado)

Hola CIB-204

Estado: Descifrado OK

EV-C204-006 — App móvil (Expo web) en el Codespace: URL del servicio, texto «Hola CIB-204», cifrado en base64 y descifrado correcto

8.5 Ajustes aplicados al Dockerfile del laboratorio

Durante la remediación de la Fase 2 el build de la imagen se rompió y el escaneo de imagen (Trivy) falló varias veces; a continuación se documenta el origen del error y los cambios aplicados (trazables por commit).

| Commit                  | Cambio                                                                                                                   | Motivo                                                                                                                                                                                  |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8b8b86e                 | Remediación: imagen fija<br>node:20-bookworm-slim,npm ci<br>--only=production, copia<br>selectiva de archivos, USER node | Cierra VULN-11/12/13 del zip<br>(CWE-1104 imagen no<br>reproducible, CWE-538 COPY . .<br>filtra secretos, CWE-250<br>ejecución como root)                                               |
| 8b8b86e<br>→<br>e267ad5 | COPY public ./public                                                                                                     | Referencia a un directorio<br>inexistente: servidor/public no<br>existe en el material y<br>servidor.js no usa<br>express.static; Docker<br>abortaba el build con /public:<br>not found |
| 5a9c481                 | Base node:20-bookworm-slim →<br>node:22-bookworm-slim                                                                    | Intento de cerrar CVEs de util-<br>linux; los CVEs persistieron (ver<br>detalle 4)                                                                                                      |

| Commit  | Cambio                                                                                                                                                                         | Motivo                                                                                                                                                                                                                                                                                                                                              |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| cc759ad | Acciones del workflow fijadas a SHA completo + nosemgrep CSRF en servidor.js                                                                                                   | Cierra 16 hallazgos Semgrep de supply chain (tags mutables @v4/@master en GitHub Actions) y documenta el falso positivo CSRF (API JWT Bearer sin cookies)                                                                                                                                                                                           |
| f3f9ab4 | <b>Multi-stage build</b> node:24-trixie-slim + apt-get upgrade + eliminación de npm del runtime + --ignore-unfixed en Trivy                                                    | Cierra los 59 hallazgos HIGH/CRITICAL de Trivy en la imagen (ver detalle 5)                                                                                                                                                                                                                                                                         |
| 657ac2f | <b>FIX-18:</b> nosemgrep CSRF movido a <b>inline</b> en servidor.js (Semgrep solo honra el comentario en la misma línea) + --exclude 'docs/**' y .semgrepignore en el job SAST | Cierra los 20 hallazgos del run 35392316892 (FIX-17): 1× CSRF (falso positivo API JWT Bearer sin cookies, ahora suprimido inline como exige Semgrep) + 19× plaintext-http-link en EV-C204-011-zap.html (evidencia DAST ZAP con links http://localhost, <b>no es código de la app</b> ; docs/ se excluye del SAST con justificación — ver 12.4/12.5) |

#### Detalle técnico:

1. **El error `"/public": not found` no se origina en el material oficial.** El Dockerfile original del material (9b1bddb) usaba `FROM node:latest + COPY . . + RUN npm install` (sin USER) y compilaba correctamente; esas malas prácticas son las vulnerabilidades intencionales VULN-11/12/13 que Trivy debía reportar.
2. Al hacer la copia selectiva en la remediación se añadió `COPY public ./public`, pero ese directorio no existe → Docker abortaba el build. Ese único fallo encadenaba 3 jobs del pipeline (Construir imagen/Trivy → Levantar servicio/ZAP → SBOM/Syft), por lo que el laboratorio no podía continuar hasta corregirlo.
3. **Corrección (e267ad5):** se eliminó la referencia inexistente `COPY public`; no se tocó código JS ni el workflow.

4. **5a9c481 mantuvo los CVEs.** El bump a node:22-bookworm-slim seguía sobre Debian bookworm (util-linux 2.38.1, afectado). El fix nunca se verificó porque GitHub había deshabilitado el workflow al activar el default setup de CodeQL (ver §8.6); al re-habilitarlo, Trivy confirmó que los CVEs persistían.
5. **Solución definitiva (f3f9ab4):** imagen base node:24-trixie-slim (Debian 13: util-linux 2.41.5, perl 5.40, zlib 1.3.1, pcre2 10.46, systemd 257, ncurses 6.5, acl 2.3.2, gzip 1.13) + apt-get upgrade para los paquetes con parche disponible (perl-base CVE-2026-13221, gzip CVE-2026-41992, pcre2, sqlite) + **multi-stage build** que elimina npm y sus dependencias empaquetadas vulnerables (tar, sigstore, pacote, ip-address, brace-expansion) del runtime. Resultado: **Trivy 0 hallazgos HIGH/CRITICAL** (verificado localmente y en el pipeline).
6. **Riesgo residual documentado:** los CVEs de util-linux (CVE-2026-53613, 76642, 78408, 78409, 78410) **no tienen versión fija** en ninguna distribución (afectan hasta 2.41.5, el más reciente). Se excluyen del fallo con --ignore-unfixed en el job de imagen y se documentan aquí como riesgo residual con plan de migración: re-escanear cuando Debian publique el parche y actualizar la imagen base.

## 8.6 Seguridad del repositorio: CodeQL default setup

1. El job sast\_codeql del pipeline (.github/workflows/devsecops.yml, *advanced setup*) fallaba con "Code scanning is not enabled for this repository" (403 default-setup): el escaneo de código es una **configuración del repositorio**, no del workflow.
2. Se habilitó **CodeQL default setup** en GitHub (Settings → Code security → Code scanning). GitHub advirtió que esto **sobrescribe el advanced setup** existente; se aceptó el cambio.
3. **El job avanzado no puede coexistir con el default setup:** al re-habilitar el workflow, CodeQL falló con "*CodeQL analyses from advanced configurations cannot be processed when the default setup is enabled*". Por eso el job sast\_codeql se **eliminó del pipeline** (commit f3f9ab4): el análisis CodeQL lo gestiona GitHub (default setup), que corre el workflow "Run CodeQL" en cada push.
4. Resultado: el pipeline queda con **5 jobs** (Semgrep, Gitleaks, SCA, Trivy+SBOM, ZAP) y CodeQL corre vía default setup. Runs verdes de referencia: pipeline **35390161512** (5/5 jobs) y CodeQL default setup **35390161555** (2 jobs: *Analyze (javascript-typescript)* y *Analyze (actions)*); el run inicial del default setup (35386648439) también quedó verde.

---

## PARTE II — IMPLEMENTACIÓN Y ENTORNO

Esta parte documenta las **decisiones de diseño** del módulo de cifrado, las utilidades, la autenticación y el pipeline. El código fuente oficial (con sus vulnerabilidades // [VULN-n]) se integra desde el material del laboratorio; aquí se documenta el diseño seguro de referencia que guía la remediación de la Fase 2.

### 9. Módulo de encriptación/desencriptación (RSA)

#### 9.1 Selección del algoritmo criptográfico

| Decisión               | Valor                   | Justificación                                                                                                                   |
|------------------------|-------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Algoritmo              | <b>RSA</b>              | Cifrado asimétrico estándar; el laboratorio lo fija                                                                             |
| Tamaño de llave        | <b>2048 bits</b>        | Mínimo recomendado por NIST (SP 800-57); ~112 bits de seguridad                                                                 |
| Padding                | <b>OAEP con SHA-256</b> | OAEP es IND-CCA2 seguro; PKCS#1 v1.5 es vulnerable al ataque de oráculo de padding (Bleichenbacher, CWE-780)                    |
| Codificación de salida | <b>Base64</b>           | Transporte seguro del texto cifrado (binario → texto)                                                                           |
| Capacidad máxima       | <b>190 bytes</b>        | RSA-2048 con OAEP-SHA256 cifra como máximo $256 - 2 \cdot 32 - 2 = 190$ bytes; el servicio lo valida y rechaza con 400 (FIX-22) |

#### 9.2 Funciones del módulo (cifrado.js)

| Función                 | Entra<br>da | Salida                       | Comportamiento seguro                                                                             |
|-------------------------|-------------|------------------------------|---------------------------------------------------------------------------------------------------|
| generarLlaves()         | —           | par<br>(pública,<br>privada) | Genera RSA-2048 al arrancar el servicio; viven solo en memoria (nunca en el código ni en el repo) |
| cifrar(textoPlano)      | texto       | texto<br>cifrado<br>(base64) | Valida entrada; usa OAEP-SHA256; falla seguro ante error                                          |
| descifrar(textoCifrado) | base64      | texto<br>plano               | Valida entrada; OAEP detecta manipulación (falla con error)                                       |

| Función | Entra<br>da | Salida | Comportamiento seguro<br>controlado) |
|---------|-------------|--------|--------------------------------------|
|---------|-------------|--------|--------------------------------------|

### 9.3 Diseño seguro de referencia vs. versión vulnerable

| Aspecto               | Versión insegura (Fase 1, esperada)                                                                     | Diseño seguro (Fase 2)                                                    |
|-----------------------|---------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| Padding               | <b>PKCS#1 v1.5 y llave de 1024 bits</b> (CWE-780 / CWE-326), confirmado en el código del commit 46cb634 | OAEP con SHA-256 explícito y llave de 2048 bits                           |
| Secretos              | Quemados en el repo (CWE-798): .env y config.js                                                         | Variables de entorno; .env fuera de git                                   |
| Validación de entrada | Ausente ([VULN-7])                                                                                      | Tipo y tamaño en bytes validados; cuerpo $\leq 10$ KB                     |
| Errores               | e.stack devuelto al cliente (CWE-209)                                                                   | Respuesta genérica; el código del error queda en la bitácora del servidor |

La columna «versión insegura» se confirmó con el código oficial del zip (commit 46cb634) y los hallazgos reales de la Tabla 3.

## 10. Funciones de utilidad

### 10.1 Validación de entrada

- **Tipo:** solo cadenas de texto (rechaza números, objetos, null): P-08.
- **Tamaño:** el cuerpo HTTP no puede pasar de 10 KB (413, P-07) y el texto no puede pasar de **190 bytes UTF-8**, la capacidad real de RSA-OAEP (400, P-07c). Mitiga DoS (CWE-400) y evita errores internos (CWE-20).
- **Vacío:** cadena vacía rechazada (400, P-06).
- **Comportamiento:** rechazo con error genérico y código HTTP adecuado.

### 10.2 Manejo de errores

- Respuestas HTTP con mensajes **genéricos** ({ "error": "Error interno" }), nunca pilas ni detalles de implementación (CWE-209): P-05.
- El código del error (por ejemplo ERR\_OSSL\_...) se registra **del lado del servidor** en la bitácora; el texto, el cifrado y el token nunca se registran.
- **Fallo seguro:** ante cualquier excepción la operación falla cerrada y no devuelve datos parciales.

### 10.3 Codificación y bitácora

- Base64 estándar para el texto cifrado; UTF-8 para el texto plano (P-25 verifica ñ, caracteres chinos y emoji).
- **Bitácora de operaciones** (requisito de **no repudio**, Tabla 1): una línea JSON por operación en la salida estándar del servicio, con marca de tiempo, acción, resultado, usuario (del token ya verificado) e IP. Ejemplo real (EV-C204-023): {"ts": "2026-09-19T12:13:06.976Z", "accion": "cifrar", "resultado": "ok", "usuario": "demo", "ip": ":::1"}. Se implementó en el commit a81aa5f porque el informe declaraba esta bitácora y el código todavía no la tenía.
- La ruta /buscar consulta una tabla bitacora en MySQL con consulta parametrizada (CWE-89 cerrado); sin base de datos configurada devuelve el SQL y el parámetro sin ejecutar nada.

## 11. Autenticación con Keycloak (JWT)

### 11.1 Flujo de identidad

1. La app móvil solicita un token a Keycloak (realm appmovil, cliente servicio-cifrado, usuario demo).
2. La app envía el token en el encabezado Authorization: Bearer <token>.
3. El servicio valida el token en auth.js **antes** de cifrar/descifrar.
4. Token válido → 200 OK; token inválido/ausente → 401.

### 11.2 Validación del token (implementada en auth.js)

| Verificación | Qué valida                                     | Cómo                                                                                                                                                                        |
|--------------|------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Firma        | El token fue emitido por el Keycloak del realm | jwt.verify() con la llave pública RSA que se obtiene del <b>JWKS</b> del realm (/realms/appmovil/protocol/openid-connect/certs) según el kid del token, con caché de 10 min |
| Algoritmo    | Solo RS256 (evita confusión de algoritmo)      | algorithms: ['RS256'] explícito; el encabezado del token solo se lee para elegir la llave, nunca para decidir la confianza                                                  |
| Expiración   | El token no está vencido                       | Claim exp (con 5 s de tolerancia de reloj)                                                                                                                                  |
| Emisor       | El token viene del realm                       | La firma ya lo garantiza (las                                                                                                                                               |

| Verificación               | Qué valida                                               | Cómo                                                                                                                                                                     |
|----------------------------|----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                            | correcto                                                 | llaves son por realm); además, si se define KEYCLOAK_ISSUER, el claim iss debe coincidir exactamente                                                                     |
| Audiencia                  | El token es para este servicio                           | aud contiene servicio-cifrado o azp (cliente autorizado) es servicio-cifrado. Keycloak emite por defecto aud: "account" y azp: "servicio-cifrado", por eso se acepta azp |
| Disponibilidad de Keycloak | Si el JWKS no responde, el servicio <b>falla cerrado</b> | Responde 503 y no deja pasar la petición                                                                                                                                 |

**Ajuste de la validación del token.** La primera versión de la Fase 2 (commit 8b8b86e) substituyó `jwt.decode()` por `jwt.verify()` con **HS256 y un secreto compartido**, lo que cerró el hallazgo de Semgrep pero no es compatible con Keycloak, que firma con RS256. Se ajustó en el commit 8b9b0b6 conforme a la guía (§10.5: «valida el token contra el JWKS de Keycloak, algorithms: [ 'RS256' ]») y a esta sección, sin agregar dependencias: se usan `jsonwebtoken`, `crypto` y `fetch` de Node.

### 11.3 Verificación contra un Keycloak real

Se levantó **Keycloak 24.0** (la misma versión del `docker-compose.yml`), se creó el realm `apmovil`, el cliente `servicio-cifrado` y el usuario `demo`, se obtuvo un token real y se ejecutó el servicio con `AUTH_ENABLED=true`. Resultados (EV-C204-023, 25 comprobaciones, todas correctas):

| Caso                                                          | Resultado              |
|---------------------------------------------------------------|------------------------|
| Sin token                                                     | 401                    |
| Token real de Keycloak                                        | 200 (cifra y descifra) |
| Token de otro cliente del mismo realm                         | 401                    |
| Token expirado (vida de 5 s, usado tras 12 s)                 | 401                    |
| Firma de otra llave RS256 / HS256 / alg:none / firma alterada | 401 en los cuatro      |

El script `scripts/prueba-e2e-keycloak.sh` repite todo el experimento (contraseñas aleatorias en cada corrida).

## 12. Pipeline DevSecOps (las 6 pruebas)

### 12.1 Diseño del pipeline

| Job          | Tipo       | Herramienta       | Qué revisa                          | Archivo generado         |
|--------------|------------|-------------------|-------------------------------------|--------------------------|
| sast_semgrep | SAST       | Semgrep           | eval, inyección, JWT, CORS, errores | reporte Semgrep          |
| sast_codeql  | SAST       | CodeQL            | Análisis con motor de GitHub        | alertas en Code scanning |
| secretos     | Secretos   | Gitleaks          | Claves y contraseñas quemadas       | reporte Gitleaks         |
| sca          | SCA        | npm audit + Trivy | Dependencias vulnerables            | SBOM                     |
| imagen       | Contenedor | Trivy + Syft      | Fallas de imagen; SBOM              | SBOM                     |
| dast         | DAST       | OWASP ZAP         | Cabeceras, CORS                     | reporte-zap              |

**Configuración de CodeQL respecto de la guía (6 pruebas):** el job `sast_codeql` del workflow se eliminó en la Fase 2 (commit `f3f9ab4`) porque el análisis CodeQL lo gestiona GitHub mediante **default setup** (Settings → Code security → Code scanning), que analiza javascript-typescript y actions en cada push (ver §8.6). Ambos modos no pueden coexistir: GitHub rechaza el análisis avanzado cuando el default setup está activo. La prueba SAST con CodeQL se ejecuta en cada push; sobre el commit final produjo 2 análisis (87 y 17 reglas) con 0 resultados abiertos. Si se requiere el job en el propio workflow, basta desactivar el default setup y restaurarlo.

### 12.2 Comportamiento por fase

- **Fase 1:** los jobs `sast_semgrep`, `secretos`, `sca` e `imagen` **fallan** (rojo) por las vulnerabilidades del código; CodeQL genera alertas (no falla el job); ZAP produce el informe de cabeceras/CORS.
- **Fase 2:** tras cada corrección (un commit por hallazgo), el job correspondiente pasa a **verde**; al final, **5/5 jobs en verde** en el run **35442482331** (commit `0fc1c11`) y **CodeQL sin alertas abiertas** sobre ese mismo commit (EV-C204-025 y EV-C204-026). La historia completa de ejecuciones está en EV-C204-029.

### 12.3 Configuración del workflow

- Se ejecuta en cada push a main (y en PRs).
- Los reportes se suben como **archivos generados** (actions/upload-artifact) para descargarlos como evidencia.
- El workflow está en `.github/workflows/devsecops.yml`; las acciones se fijan a **SHA completo** (commit cc759ad) para evitar ataques de supply chain por tags mutables.

### 12.4 Hallazgos DAST (ZAP): antes y después

El informe de ZAP de la **Fase 1** (EV-C204-022) reportó 0 High, **2 Medium**, **2 Low** y 5 informativos. El del **run verde final** (EV-C204-011, ZAP 2.17.0) reporta **0 High**, **1 Medium**, **0 Low** y 5 informativos:

| Riesgo | Hallazgo                                          | Fase 1     | Run verde                                      | Tratamiento                                                                                                                                                                  |
|--------|---------------------------------------------------|------------|------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium | Cross-Domain Misconfiguration (CORS abierto)      | ✓ presente | ✗ ya no aparece                                | <b>Corregido:</b> CORS con lista blanca                                                                                                                                      |
| Low    | Permissions Policy Header Not Set                 | ✓ presente | ✗ ya no aparece                                | <b>Corregido</b> (FIX-17): Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=() con middleware propio (Helmet 7 ya no lo incluye)                |
| Low    | Server Leaks Information via «X-Powered-By»       | ✓ presente | ✗ ya no aparece                                | <b>Corregido</b> por Helmet (quita la cabecera)                                                                                                                              |
| Medium | CSP: Failure to Define Directive with No Fallback | ✓ presente | ✓ presente (en <code>/robots.txt</code> , 404) | <b>Falso positivo:</b> Express 4.22.3 añade Content-Security-Policy: default-src 'none' en sus páginas de error/404 (CSP máximamente restrictiva); las respuestas 200 llevan |

| Riesgo                                                                                                                                                      | Hallazgo                                                  | Fase 1 | Run verde | Tratamiento                                                |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|--------|-----------|------------------------------------------------------------|
|                                                                                                                                                             |                                                           |        |           | la CSP completa de Helmet                                  |
| Informat<br>ional                                                                                                                                           | Sec-Fetch-* ausentes (×4), Storable and Cacheable Content | ✓      | ✓         | Sin tratamiento: informativos sin riesgo para una API JSON |
| ZAP en modo <i>baseline</i> es <b>pasivo</b> y no falla el job; por eso el job de DAST aparece en verde también en la Fase 1 y su valor está en el informe. |                                                           |        |           |                                                            |

## PARTE III — DIAGNÓSTICO Y REMEDIACIÓN

### 13. Fase 1 — Diagnóstico (pipeline en rojo)

#### 13.1 Qué se hizo

Se subió el proyecto **tal como llegó** (código oficial con sus trece vulnerabilidades marcadas // [VULN-1...13]), se dejó que el pipeline corriera solo y se anotó todo lo que salió en rojo. El diagnóstico se apoya en la ejecución **35365578175** (commit 46cb634, 18-sep-2026), cuyos archivos generados se descargaron íntegros (EV-C204-020, 021, 022, 027 y 028).

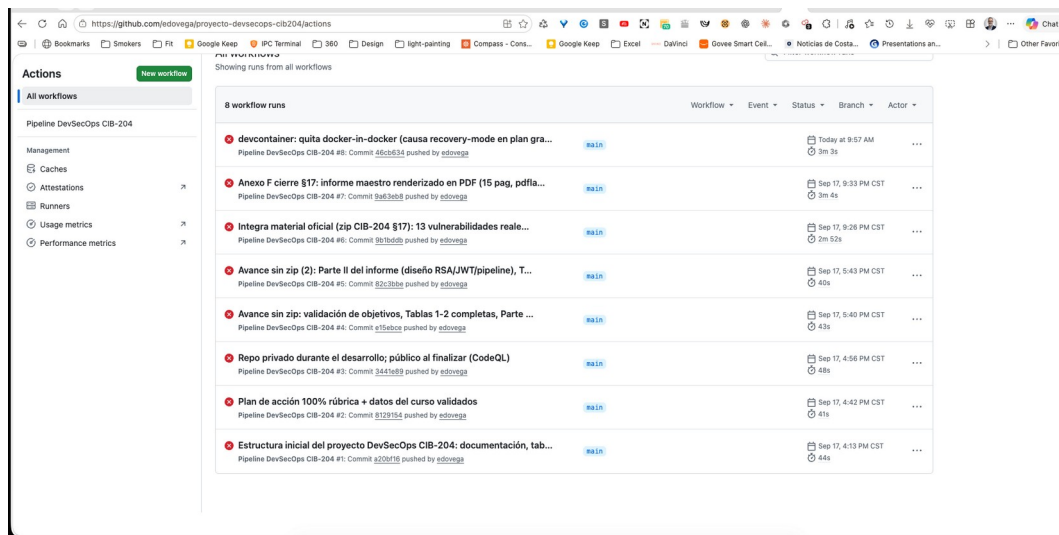
#### 13.2 Las primeras ejecuciones

GitHub Actions registró 8 ejecuciones antes de la remediación (EV-C204-047). Todas terminaron en rojo:

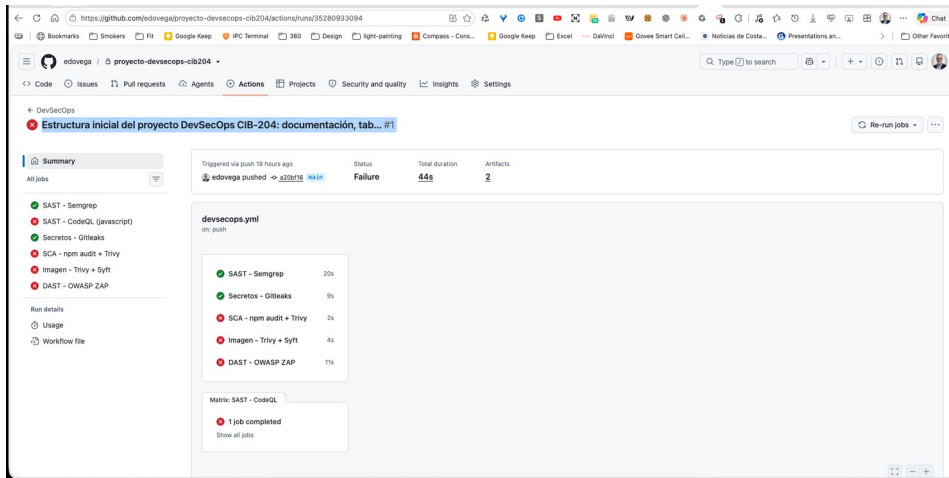
| # | Run             | Com<br>mit  | Contenido del<br>commit   | Sem<br>grep | Cod<br>eQL | Gitlea<br>ks | SCA | Ima<br>gen | ZAP |
|---|-----------------|-------------|---------------------------|-------------|------------|--------------|-----|------------|-----|
| 1 | 3528093<br>3094 | a20b<br>f16 | Estructura<br>inicial     | ✓           | ✗          | ✓            | ✗   | ✗          | ✗   |
| 2 | 3528333<br>4710 | 8129<br>154 | Plan de acción            | ✓           | ✗          | ✓            | ✗   | ✗          | ✗   |
| 3 | 3528449<br>1567 | 3441<br>e89 | Repo privado /<br>público | ✓           | ✗          | ✓            | ✗   | ✗          | ✗   |
| 4 | 3528785         | e15e<br>bce | Tablas 1-2                | ✓           | ✗          | ✓            | ✗   | ✗          | ✗   |

| # | Run             | Com<br>mit  | Contenido del<br>commit                          | Sem<br>grep | Cod<br>eQL | Gitlea<br>ks | SCA | Ima<br>gen | ZAP |
|---|-----------------|-------------|--------------------------------------------------|-------------|------------|--------------|-----|------------|-----|
|   | 8942            |             |                                                  |             |            |              |     |            |     |
| 5 | 3528810<br>2685 | 82c3<br>bbe | Parte II del<br>informe                          | ✓           | ✗          | ✓            | ✗   | ✗          | ✗   |
| 6 | 3530322<br>7701 | 9b1b<br>ddb | <b>Integra el<br/>material<br/>oficial (zip)</b> | ✗           | ✗          | ✗            | ✗   | ✗          | ✓   |
| 7 | 3530367<br>3682 | 9a63<br>eb8 | Anexo F,<br>informe en<br>PDF                    | ✗           | ✗          | ✗            | ✗   | ✗          | ✓   |
| 8 | 3536557<br>8175 | 46cb<br>634 | Codespace sin<br>docker-in-<br>docker            | ✗           | ✗          | ✗            | ✗   | ✗          | ✓   |

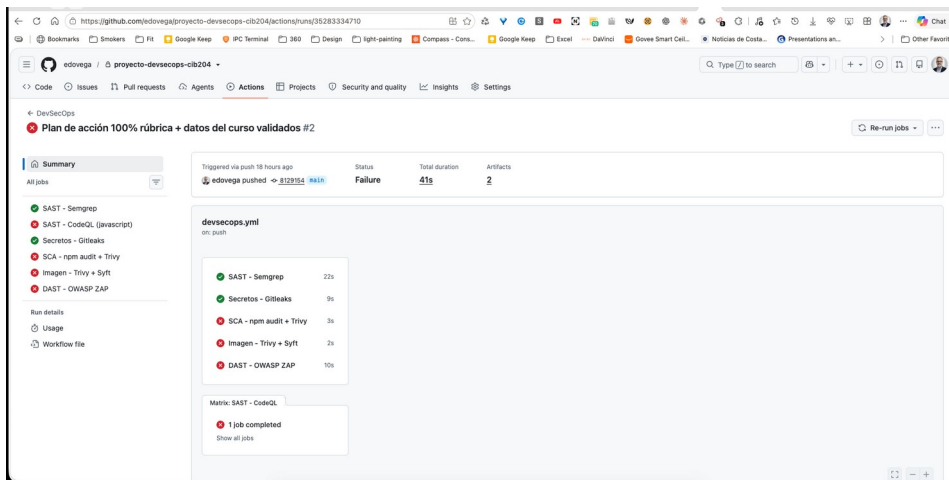
En los runs 1 a 5 aún no se había integrado el código del servicio: Semgrep y Gitleaks pasan porque no había código que analizar, y los demás jobs fallan de forma consistente con la ausencia del material (según los mensajes de commit «Avance sin zip»). Desde el run 6, con el zip oficial integrado, el pipeline queda en rojo por las vulnerabilidades del código, mientras ZAP, que solo informa, permanece en verde.



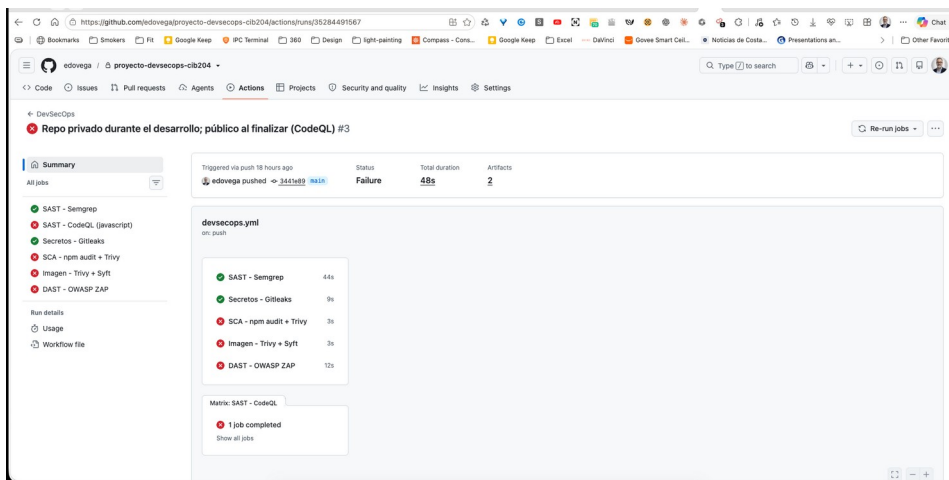
*EV-C204-047 — Pestaña Actions: las 8 ejecuciones, todas en rojo*



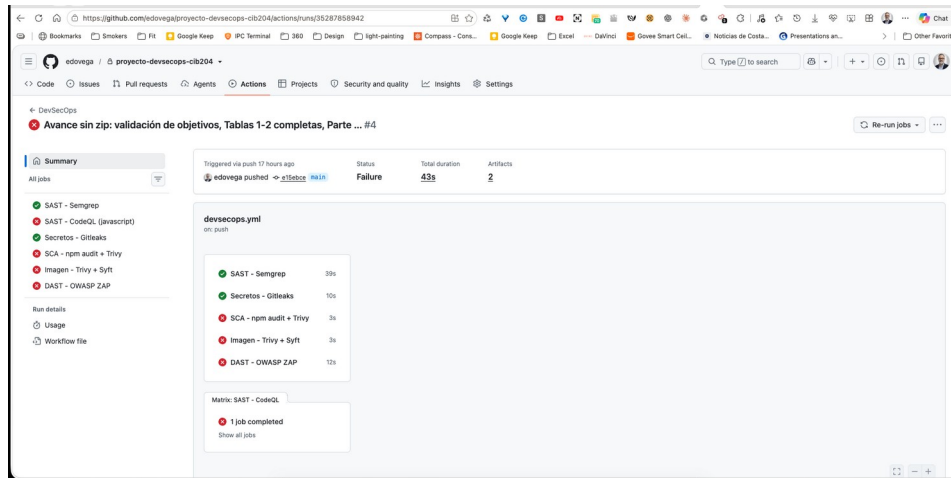
EV-C204-036 — Run #1 (35280933094, a20bf16): estructura inicial



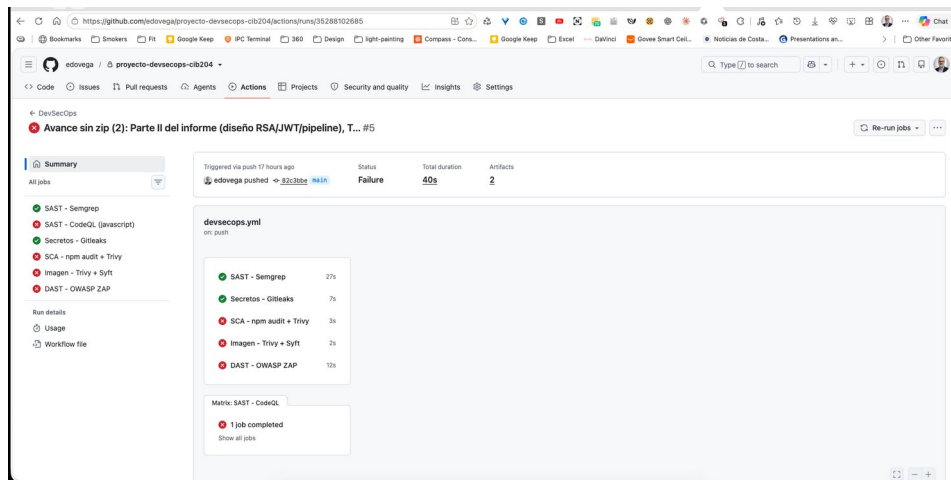
EV-C204-035 — Run #2 (35283334710, 8129154): plan de acción



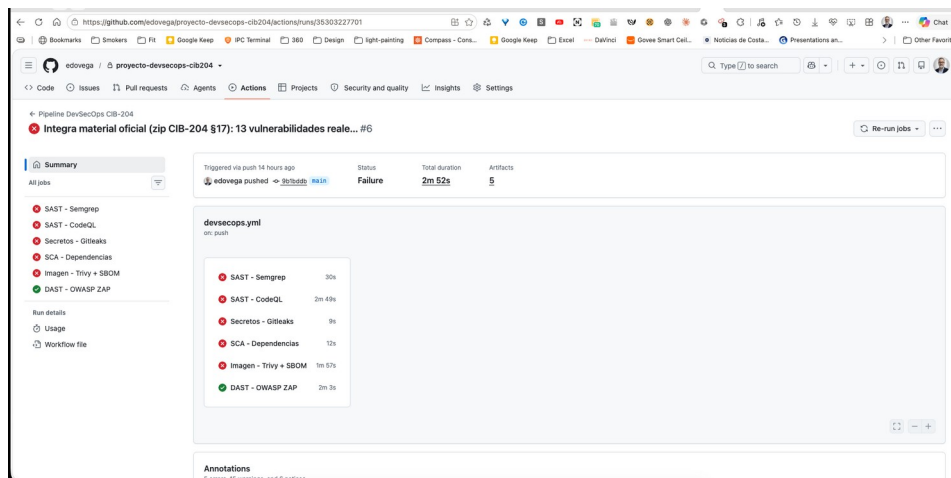
EV-C204-034 — Run #3 (35284491567, 3441e89): repo privado / público



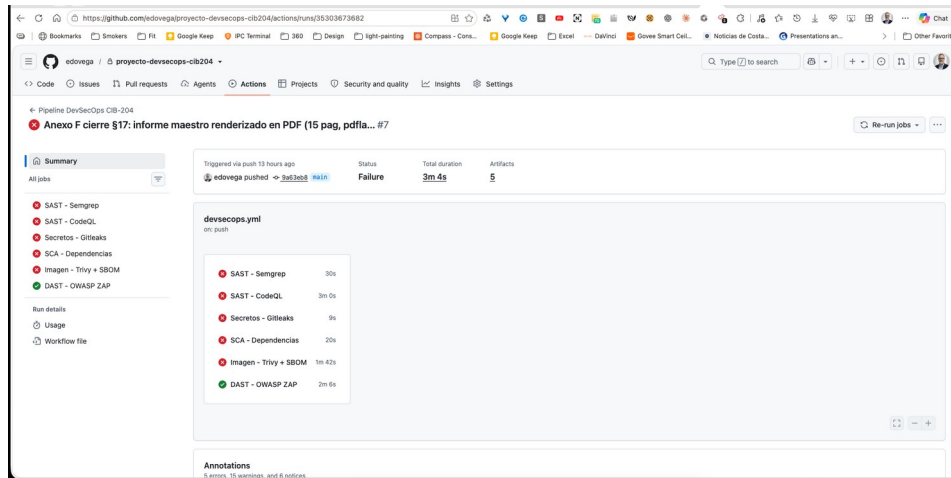
*EV-C204-033 — Run #4 (35287858942, e15ebce): validación de objetivos, Tablas 1-2*



*EV-C204-051 — Run #5 (35288102685, 82c3bbe): Parte II del informe*



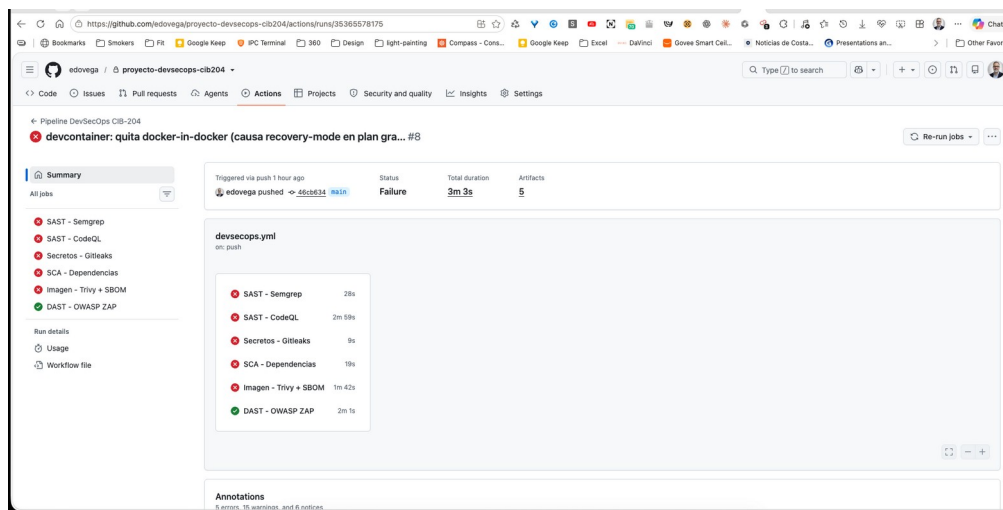
*EV-C204-050 — Run #6 (35303227701, 9b1bddb): se integra el material oficial; aparecen 5 jobs en rojo*



*EV-C204-049 — Run #7 (35303673682, 9a63eb8): mismo código, mismo resultado*

### 13.3 La ejecución de diagnóstico (run #8, 35365578175)

Seis jobs, **5 en rojo y ZAP en verde**, 3 min 3 s de duración, 5 archivos generados y 5 errores + 15 advertencias en las anotaciones.



*EV-C204-048 — Run #8: resumen de los 6 jobs (SAST-Seargrop, SAST-CodeQL, Secretos-Gitleaks, SCA e Imagen en rojo; DAST-ZAP en verde)*

Summary

All jobs

- SAST - Semgrep
- SAST - CodeQL
- Secretos - Gitleaks
- SCA - Dependencias
- Imagen - Trivy + SBOM
- DAST - OWASP ZAP

Run details

Usage

Workflow file

Artifacts

Produced during runtime

| Name                                                     | Size    | Digest                                                           |
|----------------------------------------------------------|---------|------------------------------------------------------------------|
| cifrado_46cb549232100628369947e989c1b6a2e63154.spdx.json | 2.38 MB | sha256:54fa4189c9423ec3979ffcc253fcb599bde28a8a2188d746879...    |
| reporte-gitleaks                                         | 9.35 KB | sha256:f7a7e546f97c7f70b8c18821388654541d0b42458e1c38157d266c... |
| reporte-semgrep                                          | 188 KB  | sha256:2246b62af63a246af4e474ba3841c352589568f3592a82d413685...  |
| reporte-zap                                              | 15.9 KB | sha256:c0dc87838f9f3ba33948fec208c946b08d57836e2ad3426b06...     |
| sbom                                                     | 2.38 MB | sha256:7b1444d8b4aa5731833462e893733cc3ca4861e0b13e5c37b...      |

*EV-C204-038 — Archivos generados del run #8 con su huella SHA-256: los de reporte-gitleaks, reporte-semgrep y reporte-zap coinciden con los zip instalados (EV-C204-020, 021 y 022)*

**Semgrep — 23 hallazgos (Error: Process completed with exit code 1):**

Summary

All jobs

- SAST - Semgrep
- SAST - CodeQL
- Secretos - Gitleaks
- SCA - Dependencias
- Imagen - Trivy + SBOM
- DAST - OWASP ZAP

Run details

Usage

Workflow file

SAST - Semgrep

failed 2 hours ago in 23s

Search logs

Explain error

Ejecutar Semgrep

Scanning 47 files tracked by git with 1875 code rules:

| Language   | Rules | Files | Origin    | Rules |
|------------|-------|-------|-----------|-------|
| multilang  | 47    | 47    | Community | 1875  |
| js         | 124   | 9     |           |       |
| json       | 4     | 6     |           |       |
| bash       | 4     | 3     |           |       |
| yaml       | 35    | 2     |           |       |
| dockerfile | 6     | 1     |           |       |

Scan Summary

Scan completed successfully.

- Findings: 23 (23 blocking)
- Rules run: 246
- Targets scanned: 47
- Parsed lines: ~380.4k
- Scan was limited to files tracked by git
- For a detailed list of skipped files and lines, run semgrep with the --verbose flag
- Run 246 rules on 47 files: 23 findings

Error: Process completed with exit code 1.

Guardar reporte Semgrep

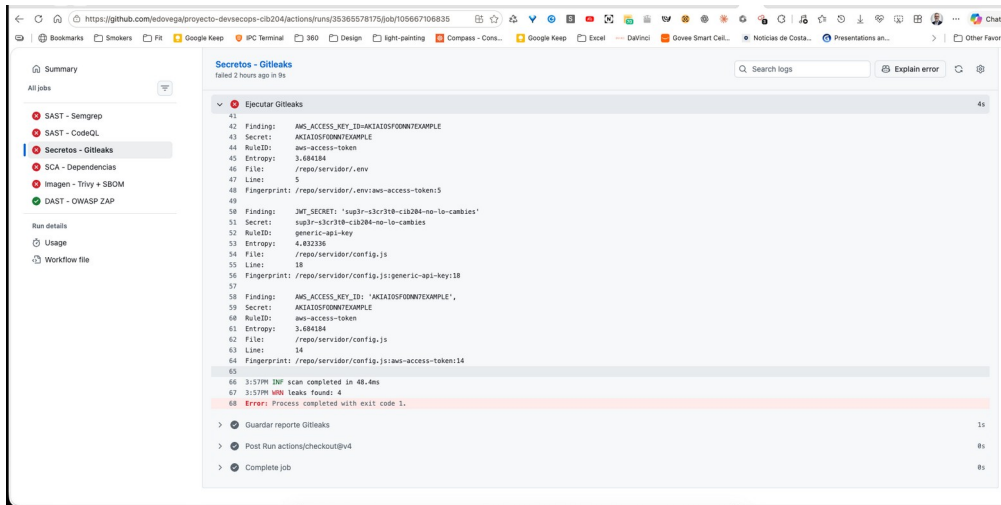
Post Run actions/checkout@v4

Stop containers

Complete job

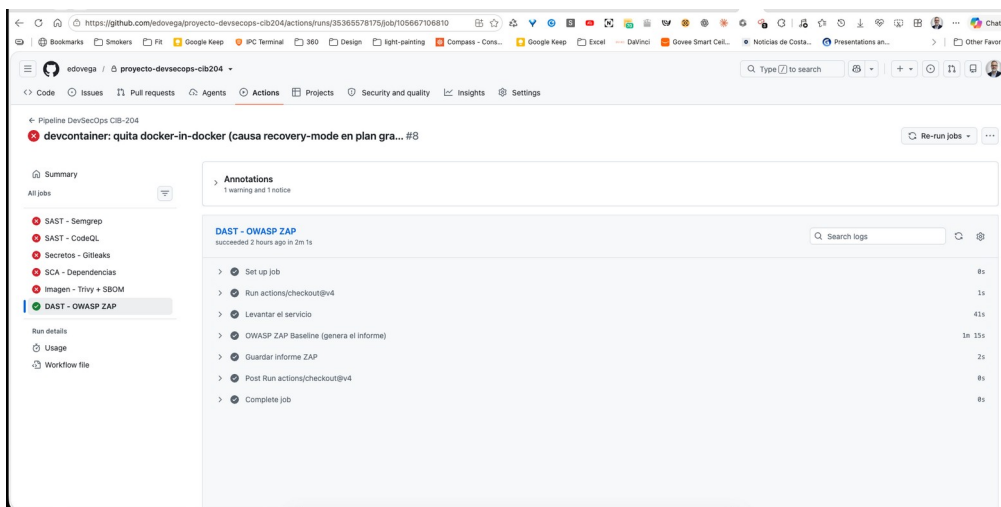
*EV-C204-040 — Log de SAST-Semgrep: 23 hallazgos bloqueantes*

**Gitleaks — 4 secretos en servidor/.env y servidor/config.js:**



*EV-C204-041 — Log de Secretos-Gitleaks: leaks found: 4 (aws-access-token y generic-api-key)*

**ZAP — informa pero no falla (0 High, 2 Medium, 2 Low, 5 informativos):**



*EV-C204-042 — Job DAST-OWASP ZAP: exitoso en 2 min 1 s; el valor está en el informe reporte-zap*

Las capturas EV-C204-037 y EV-C204-039 son la misma página del run #8 tomada en otros momentos («hace 1 hora» y «hace 2 horas») y se conservan como respaldo (Anexo I).

## 13.4 Resultados del diagnóstico

Prueba

Resultado real en la Fase 1

SAST – Semgrep

23 hallazgos: 16 de cadena de suministro (acciones sin SHA), eval(), concatenación de código, exec(), SQL

| Prueba                | Resultado real en la Fase 1                                                                                       |
|-----------------------|-------------------------------------------------------------------------------------------------------------------|
|                       | injection, JWT alg:none, contenedor root, CSRF (falso positivo)                                                   |
| SAST – CodeQL         | Job avanzado en rojo por configuración del repositorio (no por hallazgos; §8.6)                                   |
| Secretos – Gitleaks   | 4 secretos (2 llaves AWS de ejemplo y 2 secretos genéricos)                                                       |
| SCA – Dependencias    | npm audit: 13 vulnerabilidades (3 low, 1 moderate, 8 high, 1 critical): axios 0.18.0 y lodash 4.17.4, entre otras |
| Imagen – Trivy + SBOM | 640 hallazgos (583 HIGH, 57 CRITICAL) sobre node:latest                                                           |
| DAST – ZAP            | 0 High, 2 Medium (CORS, CSP), 2 Low (Permissions-Policy, X-Powered-By), 5 informativos                            |

Todo se detalla, con archivo, línea y CWE, en la **Tabla 3** (16 hallazgos H-01 a H-16): docs/tablas/tabla-3-diagnostico.md.

**Observación metodológica.** Cuatro debilidades del código oficial no fueron reportadas por ninguna herramienta (RSA de 1024 bits con PKCS#1 v1.5, e.stack devuelto al cliente, COPY . . en el Dockerfile y falta de validación de entrada). Se identificaron mediante la revisión del código y de sus marcadores [VULN-n], por lo que el pipeline complementa la revisión de código, pero no la sustituye.

## 14. Fase 2 — Remediación (de rojo a verde)

### 14.1 Método

Se corrigió por orden de riesgo (Tabla 5), un commit por grupo de hallazgos, y se verificó cada uno con una nueva ejecución del pipeline. La trazabilidad completa (commit → hallazgo → corrida) está en la **Tabla 4**: docs/tablas/tabla-4-evidencias.md. El playbook de patrones de corrección está en docs/remediacion-playbook.md.

### 14.2 Recorrido real de rojo a verde

| Run             | Com<br>mit  | Qué cambió      | Semg<br>rep | Gitleak<br>s | SCA | Ima<br>gen | ZAP |
|-----------------|-------------|-----------------|-------------|--------------|-----|------------|-----|
| 35365578<br>175 | 46cb<br>634 | (Fase 1)        | ✗           | ✗            | ✗   | ✗          | ✓   |
| 35381118        | 8b8b<br>86e | Remediación del | ✗           | ✓            | ✓   | ✗          | ✗   |

| Run                | Com<br>mit | Qué cambió                                        | Semg<br>rep | Gitleak<br>s | SCA | Ima<br>gen | ZAP |
|--------------------|------------|---------------------------------------------------|-------------|--------------|-----|------------|-----|
| 104                |            | servidor (13 hallazgos)                           |             |              |     |            |     |
| 35382450884        | e267ad5    | Quita COPY public (error introducido al remediar) | ✗           | ✓            | ✓   | ✗          | ✓   |
| 35389584392        | cc759ad    | Acciones a SHA completo + nosemgrep CSRF          | ✓           | ✓            | ✓   | ✗          | ✓   |
| <b>35390161512</b> | f3f9ab4    | Imagen multi-stage node:24-trixie-slim            | ✓           | ✓            | ✓   | ✓          | ✓   |
| 35392316892        | 0f5da25    | Permissions-Policy                                | ✗           | ✓            | ✓   | ✓          | ✓   |
| <b>35405835472</b> | 657ac2f    | Semgrep excluye docs/                             | ✓           | ✓            | ✓   | ✓          | ✓   |
| 35441584999        | 8b9b0b6    | Auth RS256/JWKS de Keycloak                       | ✗           | ✓            | ✓   | ✓          | ✓   |
| 35441709157        | c27d28d    | Secreto aleatorio en la prueba                    | ✓           | ✓            | ✓   | ✓          | ✓   |
| 35441885522        | 500b39c    | Límite de peticiones (CodeQL)                     | ✓           | ✓            | ✓   | ✓          | ✓   |
| 35442133748        | a81aa5f    | OAEP-SHA256 y bitácora                            | ✓           | ✓            | ✓   | ✓          | ✓   |
| <b>35442482331</b> | 0fc1c11    | Límite de entrada = 190 bytes                     | ✓           | ✓            | ✓   | ✓          | ✓   |

(En los runs anteriores a f3f9ab4 el job CodeQL avanzado seguía existiendo y fallaba; ver §8.6.) La secuencia refleja el ciclo *encontrar* → *corregir* → *volver a probar*: la referencia inexistente COPY public interrumpió la construcción de la imagen (§8.5), la actualización a node:22 no eliminó los CVEs y dos correcciones activaron de nuevo Semgrep hasta ser ajustadas.

#### 14.3 Estado final (run 35442482331, commit 0fc1c11)

| Prueba   | Fase 1 | Fase 2                                                                            |
|----------|--------|-----------------------------------------------------------------------------------|
| Semgrep  | 23     | <b>0 activos</b> (1 falso positivo CSRF suprimido en el código con justificación) |
| Gitleaks | 4      | <b>0</b>                                                                          |

| Prueba            | Fase 1          | Fase 2                                                                               |
|-------------------|-----------------|--------------------------------------------------------------------------------------|
| npm audit         | 13 (1 crítica)  | <b>0</b>                                                                             |
| Trivy<br>(imagen) | 640             | <b>0</b> con --ignore-unfixed (riesgo residual: CVEs de util-linux sin parche, §8.5) |
| ZAP               | 2 Medium, 2 Low | <b>0 High, 1 Medium (falso positivo), 0 Low</b>                                      |
| CodeQL            | —               | <b>0 alertas abiertas</b> (3 de <i>rate limiting</i> halladas y corregidas)          |
| Pruebas Jest      | 6 (guía)        | <b>22</b>                                                                            |

Evidencia: EV-C204-008 a 011 (reportes del run verde), EV-C204-012, EV-C204-013, EV-C204-025 y 026.

edovega / proyecto-devsecops-cib204

Code

Issues

Pull requests

Agents

Actions

Projects

Wiki

Security and quality

Insights

Settings

← Pipeline DevSecOps CIB-204

fix(servidor): FIX-22 límite de entrada = capacidad real de RSA-OAEP ... #27

Re-run all jobs

Summary

All jobs

SAST - Semgrep

Secretos - GitLeaks

SCA - Dependencias

Imagen - Trivy + SBOM

DAST - OWASP ZAP

Run details

Usage

Workflow file

Triggered via push 3 hours ago

edovega pushed → 0fc1c11

main

Status

Success

Total duration

1m 29s

Artifacts

5

devsecops.yml

on: push

SAST - Semgrep28s

Secretos - GitLeaks10s

SCA - Dependencias22s

Imagen - Trivy + SBOM46s

DAST - OWASP ZAP1m 25s

Annotations

5 warnings and 5 notices

Secretos - GitLeaks

Node.js 28 is deprecated. The following actions target Node.js 28 but are being forced to run on Node.js 24: actions/checkout@1d5960a32679d5838878e36cf38b85af677262, actions/upload-artifact@ea165f8...

Show more

SCA - Dependencias

Node.js 28 is deprecated. The following actions target Node.js 28 but are being forced to run on Node.js 24: actions/checkout@1d5960a32679d5838878e36cf38b85af677262, actions/setup-node@49933ea5288c...

Show more

SAST - Semgrep

Node.js 28 is deprecated. The following actions target Node.js 28 but are being forced to run on Node.js 24: actions/checkout@1d5960a32679d5838878e36cf38b85af677262, actions/upload-artifact@ea165f8...

Show more

Imagen - Trivy + SBOM

Node.js 28 is deprecated. The following actions target Node.js 28 but are being forced to run on Node.js 24: actions/checkout@1d5960a32679d5838878e36cf38b85af677262, actions/upload-artifact@ea165f8...

Show more

DAST - OWASP ZAP

Node.js 28 is deprecated. The following actions target Node.js 28 but are being forced to run on Node.js 24: actions/checkout@1d5960a32679d5838878e36cf38b85af677262, actions/upload-artifact@ea165f8...

Show more

Secretos - GitLeaks

"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/issues/14748"

SCA - Dependencias

"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/issues/14748"

SAST - Semgrep

"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/issues/14748"

Imagen - Trivy + SBOM

"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/issues/14748"

DAST - OWASP ZAP

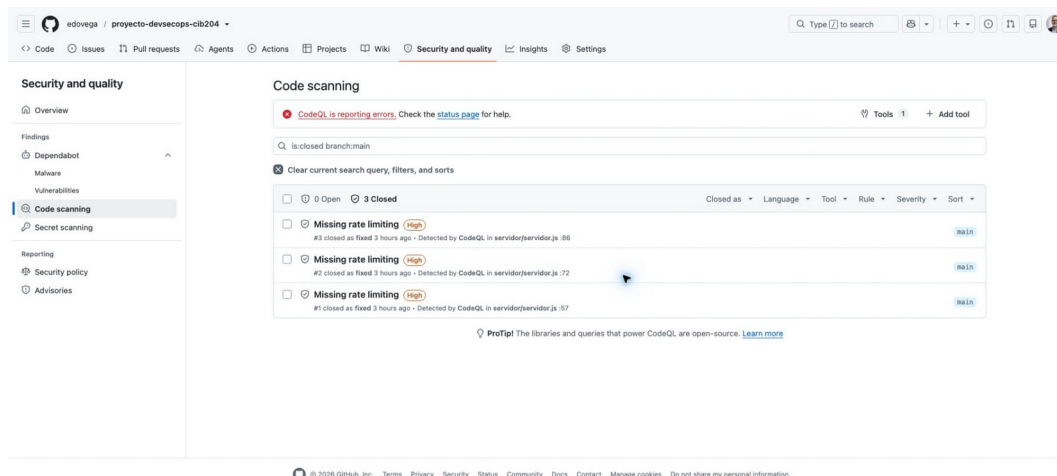
"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/issues/14748"

Artifacts

Produced during runtime

| Name                                                      | Size    | Digest                                                            |  |  |
|-----------------------------------------------------------|---------|-------------------------------------------------------------------|--|--|
| cifrado_0fc1c11b2a63f8ef34fc6c8fba10a7480170346.spdx.json | 301 KB  | sha256:8573a45d8f88c73852f54783266a6576c3452ff911c56335669772...  |  |  |
| reporte-gitileaks                                         | 8.99 KB | sha256:13277b285ba788ce32b76408ce81671c64c162c1b6a6814b4b19bae... |  |  |
| reporte-semgrep                                           | 186 KB  | sha256:e83eac88d7f65df2747b2d1684b88a931886c49262831184c3172e...  |  |  |
| reporte-zap                                               | 14.6 KB | sha256:5e8bf14df1eabdc42cb88978a11be8de552d28c187c9ba72a499bc3... |  |  |
| sbom                                                      | 301 KB  | sha256:889288838442c2352834383e3492c23e1641e764c451646f888f2...   |  |  |

EV-C204-013 — Run #27 (35442482331, commit 0fc1c11): los 5 jobs en verde y 5 archivos generados con su huella SHA-256



El script

scripts/verificar-evidencia.sh <RUN> demuestra que esos cuatro reportes son **byte a byte idénticos** a los archivos generados del run.

## 14.4 Ajustes de conformidad con la guía y con el informe

La revisión final del código frente a la guía y a este informe dio lugar a cuatro ajustes que el pipeline no detecta; todos fueron implementados y probados:

| Commit  | Diferencia                                                                                                           | Corrección                                        |
|---------|----------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| 8b9b0b6 | auth.js usaba HS256 con secreto compartido: los tokens RS256 reales de Keycloak habrían sido rechazados              | Validación RS256 con el JWKS del realm (\$11)     |
| 500b39c | Sin límite de peticiones (3 alertas <i>high</i> de CodeQL)                                                           | express-rate-limit: 100/min por IP                |
| a81aa5f | El informe declaraba OAEP-SHA256 pero Node usa SHA-1 por defecto; y declaraba bitácora de operaciones que no existía | oaepHash: 'sha256' y bitácora JSON                |
| 0fc1c11 | Textos de más de 190 bytes daban «Error interno» (500)                                                               | Validación en bytes = capacidad de RSA-OAEP (400) |

## 15. Protección de la rama principal

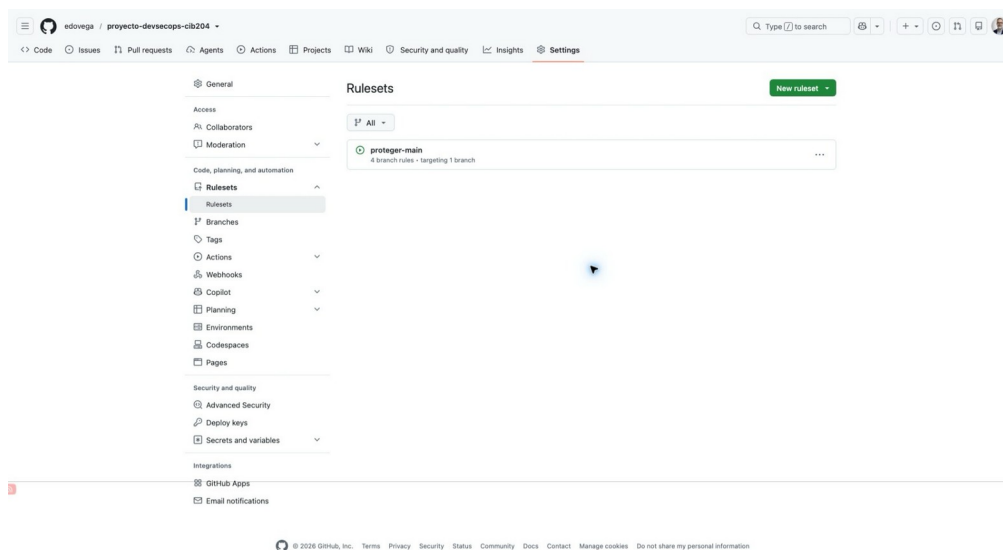
**Estado: activada el 19-sep-2026 por el titular del repositorio** (cambiar la configuración de seguridad de un repositorio es decisión de quien lo administra, por lo que no se aplicó automáticamente). La guía (paso 14) pide proteger main.

Configuración aplicada (Settings → Rules → Rulesets → ruleset proteger-main, activo, objetivo: rama por defecto main, sin excepciones de *bypass*):

1. **Restrict deletions y Block force pushes.**
2. **Require status checks to pass**, con las cinco pruebas del pipeline: SAST - Semgrep, Secretos - Gitleaks, SCA - Dependencias, Imagen - Trivy + SBOM, DAST - OWASP ZAP.
3. **Require a pull request before merging** (0 aprobaciones si se trabaja solo).

Se verificó la configuración real con la API de GitHub (EV-C204-030-ruleset-main.json): reglas deletion, non\_fast\_forward, pull\_request (0 aprobaciones) y required\_status\_checks con los cinco nombres exactos del pipeline.

**Consecuencia:** desde este momento todo cambio a main entra por *pull request* y solo se puede fusionar con las cinco pruebas en verde.



*EV-C204-014 — Rulesets del repositorio: proteger-main activo, 4 reglas, 1 rama*

**Evidencia:** EV-C204-014 y EV-C204-030.

---

## PARTE IV — PRUEBAS Y RIESGOS

### 16. Cálculo de riesgo

Ver **Tabla 5** completa en docs/tablas/tabla-5-riesgo.md

Riesgo = Probabilidad × Impacto (escala 1–3). Se calculó **antes** (con los hallazgos confirmados de la Fase 1) y **después** (con la evidencia del run verde):

|                                           | Antes           | Después                |
|-------------------------------------------|-----------------|------------------------|
| Suma de riesgos (13 riesgos)              | <b>73</b>       | <b>31</b> (–58 %)      |
| Riesgos en nivel Alto                     | <b>6</b>        | <b>0</b>               |
| Pérdida anual esperada (ALE, ilustrativa) | <b>\$34,000</b> | <b>\$9,500</b> (–72 %) |

Riesgo residual aceptado: CVEs de util-linux sin parche, falso positivo de ZAP en respuestas 404 y secretos ficticios que permanecen en el historial de git.

## 17. Documentación de pruebas

Ver **Tabla 6** completa en docs/tablas/tabla-6-pruebas.md

| Nivel                                                                      | Cantidad          | Resultado                                     | Evidencia   |
|----------------------------------------------------------------------------|-------------------|-----------------------------------------------|-------------|
| Pruebas Jest (unitarias e integración)                                     | 22 en 5 archivos  | ✓ 22 pasan                                    | EV-C204-024 |
| Análisis estático (ESLint)                                                 | —                 | ✓ 0 errores, 0 advertencias                   | EV-C204-024 |
| Extremo a extremo con Keycloak 24.0 real                                   | 25 comprobaciones | ✓ 25 pasan (3 corridas consecutivas estables) | EV-C204-023 |
| Pentest manual (token, cabeceras, CORS, fuerza bruta, manipulación, borde) | P-17 a P-26       | ✓ un defecto hallado y corregido (FIX-22)     | Tabla 6     |
| Pipeline (5 jobs + CodeQL)                                                 | 6 pruebas         | ✓ verde                                       | EV-C204-026 |

**Ajustes de pruebas** (criterio «pruebas y ajustes de código»): la Tabla 6 documenta siete ajustes reales, entre ellos la ampliación de P-10 y P-07, la corrección de una prueba de firma alterada que a veces daba un falso resultado, y la sensibilidad al reloj de la expiración de tokens.

**Ejecutadas por el equipo en el Codespace:** P-27 (app móvil, EV-C204-006) y P-28 (Keycloak, EV-C204-003 a 005).

## 18. Plantilla de diagnóstico del curso

Ver docs/plantilla-diagnostico.md — registro de 16 vulnerabilidades con CWE, severidad y consecuencia, y cálculo probabilístico de riesgo.

---

## PARTE V — CIERRE ACADÉMICO

### 19. Resumen de resultados

**Vulnerabilidades identificadas.** 16 hallazgos en la Fase 1: 12 confirmados por las herramientas del pipeline (Sengrep 23 coincidencias en 8 reglas, Gitleaks 4, npm audit 13, Trivy 640, ZAP 9 alertas) y 4 por revisión de código (Tabla 3).

**Riesgos asociados.** Antes de corregir había 6 riesgos en nivel Alto (secretos, dependencias, eval/exec, JWT, criptografía débil y ausencia de límite de peticiones), con una suma de riesgo de 73. Después quedan 0 riesgos Altos y una suma de 31 (Tabla 5).

**Efectividad de las medidas.** Se midió con la misma herramienta que encontró el problema, y con pruebas independientes:

| Medida                                              | Prueba de efectividad                                                                             |
|-----------------------------------------------------|---------------------------------------------------------------------------------------------------|
| Secretos fuera del código                           | Gitleaks 4 → 0                                                                                    |
| Dependencias mínimas y actualizadas                 | npm audit 13 → 0                                                                                  |
| Sin eval()/exec(); consulta SQL parametrizada       | Sengrep 23 → 0 activos; endpoints eliminados devuelven 404                                        |
| Autenticación RS256 + JWKS de Keycloak              | 9 pruebas unitarias + 25 comprobaciones con Keycloak real; los 6 tipos de token falso reciben 401 |
| RSA-2048 con OAEP-SHA256                            | 3 pruebas dedicadas; la confusión SHA-1 falla                                                     |
| Helmet + CORS con lista blanca + Permissions-Policy | ZAP: 2 Medium + 2 Low → 1 Medium (falso positivo) + 0 Low                                         |
| Imagen multi-stage, sin npm, usuario node           | Trivy 640 → 0 (--ignore-unfixed); el contenedor corre como node                                   |
| Límite de peticiones                                | CodeQL 3 alertas → 0; 76 × 200 y 54 × 429 en la prueba de 130 peticiones                          |

| Medida                  | Prueba de efectividad                                   |
|-------------------------|---------------------------------------------------------|
| Bitácora de operaciones | P-24: la operación queda registrada y el texto plano no |

## 20. Conclusiones

1. **El ciclo DevSecOps funcionó como método.** El pipeline detectó de forma automática y repetible la mayoría de las debilidades, y cada corrección se verificó con una nueva ejecución. La trazabilidad commit → hallazgo → corrida (Tabla 4) permite demostrarlo.
2. **Un pipeline en verde no equivale, por sí solo, a la corrección funcional del servicio.** La validación de tokens contra Keycloak, el hash de OAEP, la bitácora de operaciones y el límite de entrada requirieron pruebas funcionales contra un Keycloak 24.0 y la revisión del código frente a la guía, además de las herramientas automáticas.
3. **Las herramientas no lo ven todo.** Cuatro de las dieciséis debilidades de la Fase 1 (cifrado débil, errores expuestos, COPY . . ., falta de validación) no las reportó ninguna herramienta.
4. **Cada herramienta produce ruido que hay que juzgar.** Se documentaron dos falsos positivos (CSRF de Semgrep en una API con Bearer sin cookies; CSP en respuestas 404 de ZAP) en lugar de suprimirlos sin explicación, y un riesgo residual real (util-linux sin parche).
5. **Cada corrección requiere verificación posterior.** Durante la remediación, la referencia inexistente COPY public interrumpió la construcción de la imagen y dos ajustes volvieron a activar Semgrep, lo que confirma la necesidad de verificar tras cada cambio.
6. **Evaluación de seguridad de la aplicación.** En el estado final, el servicio exige identidad de Keycloak, cifra con RSA-2048 OAEP-SHA256, valida la entrada según su capacidad real, limita las peticiones, falla cerrado, no filtra detalles internos, registra las operaciones sin datos sensibles y corre como usuario sin privilegios; el riesgo agregado bajó  $\approx 58\%$  y no quedan riesgos Altos.
7. **Alcance y límites.** La app móvil y Keycloak funcionaron en el Codespace del equipo (EV-C204-005 y 006); Docker 29.8.1 verificado en el Codespace corregido (EV-C204-001b); las llaves RSA se generan en memoria y se pierden al reiniciar (adecuado para un laboratorio, no para producción).

## 21. Recomendaciones

**Sobre las vulnerabilidades halladas:** 1. **Rotar** cualquier credencial que haya estado en el historial de git (aquí eran ficticias) y, en un proyecto real, reescribir el historial. 2. **Mantener la protección de main** (\$15, ya activa) y, si el equipo crece, exigir al menos una aprobación de revisión. 3. **Automatizar dependencias:** Dependabot con alertas de seguridad y una política SCA que bloquee severidad *high* o *critical*. 4. **Re-escanear la imagen** de forma periódica para cerrar los CVEs de util-linux cuando exista parche, y retirar `--ignore-unfixed` entonces.

**Medidas adicionales de seguridad:** 5. **Persistir las llaves RSA** en un almacén seguro (KMS o secreto gestionado) y rotarlas; hoy se generan en memoria al arrancar y los datos cifrados dejan de poder descifrarse al reiniciar. 6. **TLS en el borde** (proxy inverso) y cabecera HSTS efectiva; en el laboratorio el TLS lo termina el reenvío de puertos de Codespaces. 7. **Cifrado híbrido** (RSA + AES-GCM) si se necesitan textos de más de 190 bytes: hoy RSA-OAEP directo limita el mensaje. 8. **Monitoreo:** enviar la bitácora JSON a un sistema centralizado con alertas ante ráfagas de 401 o 429. 9. **Keycloak en modo producción** (base de datos, HTTPS, sin start-dev, sin credenciales por defecto) y **MFA** para los usuarios. 10. **Pruebas de la app móvil:** análisis de la app con MASVS (almacenamiento del token, *certificate pinning*) y una prueba de flujo completo automatizada. 11. **Mantener la revisión manual** del código junto al pipeline, dado la observación metodológica de §13.4.

## 22. Referencias

- Helfrich, J. (2019). *Security for Software Engineers*. Taylor & Francis Group.
- Johnsson, D., Deogun, D. y Sawano, D. (2019). *Secure by Design*. Manning Publications.
- Hoffman, A. (2020). *Web Application Security: Exploitation and countermeasures for modern web applications*. O'Reilly Media.
- NIST. (2021). *Secure Software Development Framework (SSDF)*, SP 800-218.
- OWASP. *Software Assurance Maturity Model (SAMM)*.
- OWASP. *Application Security Verification Standard (ASVS)*.
- OWASP. *Mobile Application Security Verification Standard (MASVS)*.
- Microsoft. *STRIDE threat model*.
- MITRE. *Common Weakness Enumeration (CWE)*.
- Keycloak. *Server Administration Guide y Securing Applications (OIDC, JWKS)*, versión 24.0.

- IETF. (2015). *RFC 7519: JSON Web Token (JWT)* y (2015) *RFC 7517: JSON Web Key (JWK)*.
  - IETF. (2016). *RFC 8017: PKCS #1: RSA Cryptography Specifications v2.2 (OAEP)*.
  - Universidad CENFOTEC. (2026). *Guía de laboratorio — Pipeline DevSecOps y CIB-204 Seguridad del Software* (programa del curso).
- 

## 23. Cobertura de la rúbrica del proyecto

La rúbrica del curso (programa CIB-204, «Proyecto de seguridad en aplicaciones móviles», 40 %) evalúa nueve criterios. Dónde se cumple cada uno:

| Criterio de la rúbrica                            | Dónde se demuestra                                                                                                 | Evidencia                                 |
|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|-------------------------------------------|
| Requerimientos de seguridad                       | §5 y §6 (confidencialidad, integridad, disponibilidad y autenticación, más no repudio); Tabla 1 y Tabla 2 (STRIDE) | Tablas 1-2; §6.1 (8 casos de abuso)       |
| Configuración del entorno de programación Node.js | §8.1 (Codespace, Node 20, incidente y solución) y §8.5 (Dockerfile)                                                | EV-C204-043 a 046                         |
| Módulo de encriptación y desencriptación          | §9 (cifrado.js: generar llaves, cifrar, descifrar)                                                                 | P-01, P-02; cifrado.test.js, oaep.test.js |
| Funciones de utilidad                             | §10 (validación de entrada, errores genéricos, bitácora)                                                           | P-06 a P-08, P-24, P-25                   |
| Algoritmo criptográfico RSA                       | §9.1 (RSA-2048, OAEP-SHA256, capacidad de 190 bytes)                                                               | oaep.test.js (3), P-07b/c                 |
| Revisión del código con análisis estático         | §12–§14 (Semgrep, CodeQL, ESLint, más Gitleaks, SCA, Trivy y ZAP)                                                  | EV-C204-008/009/021, EV-C204-025          |
| Pruebas y ajustes de código                       | §17 y Tabla 6 (22 pruebas Jest, 25 extremo a extremo, 7 ajustes documentados)                                      | EV-C204-023, EV-C204-024                  |
| Avances del proyecto                              | Anexo D (historial de 30 commits) y Anexo E; 22+                                                                   | EV-C204-029                               |

| Criterio de la rúbrica                              | Dónde se demuestra                                                                                                                | Evidencia           |
|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|---------------------|
|                                                     | ejecuciones del pipeline                                                                                                          |                     |
| Informe del proyecto (formato PDF con conclusiones) | Este documento: introducción (§1–§4), desarrollo (§5–§18), resumen de resultados (§19), conclusiones (§20), recomendaciones (§21) | informe-maestro.pdf |

Las **prácticas de diagnóstico** (30 %) se apoyan en la jerarquía de diseño (§7 y `jerarquia_diseno.md`), la descomposición de subsistemas y el análisis de componentes críticos (§7.1–§7.2), la plantilla de diagnóstico (§18) y el cálculo probabilístico de riesgo (§16, Tabla 5). El código fuente se entrega en el repositorio Git público, como pide el curso.

## Anexos

- **Anexo A:** Tablas 1–6 completas
- **Anexo B:** Reportes del pipeline (Semgrep, Gitleaks, SBOM, ZAP, CodeQL)
- **Anexo C:** Manifiesto SHA-256 de evidencias
- **Anexo D:** Historial de versiones del repositorio
- **Anexo E:** Cronograma del proyecto
- **Anexo F:** Guía de lectura (evidencias, siglas y archivos)
- **Anexo G:** Glosario y convenciones
- **Anexo H:** Uso de herramientas de IA
- **Anexo I:** Capturas de consola Git por slide (EV-C204-033..051)
- **Anexo J:** Cómo verificar este informe (para revisión externa)

## Anexo A — Tablas 1–6 completas

### Tabla 1 — Requisitos de seguridad

Primer Avance. Define qué debe proteger el sistema antes de tocar código. Marco de referencia: OWASP SAMM, NIST SSDF, OWASP ASVS y OWASP MASVS.

### Requisitos de seguridad

| Propiedad                           | Requisito (qué debe cumplir)                                         | Control que lo implementa                                                                       | Cómo se verifica                                                                                  |
|-------------------------------------|----------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| Confidencialidad                    | Los datos se cifran antes de viajar entre la app y el servicio       | Cifrado RSA-2048 con padding OAEP-SHA256 en <code>cifrado.js</code>                             | Prueba de cifrar/descifrar (roundtrip); DAST (ZAP) confirma que no hay fuga por errores           |
| Integridad                          | Un dato alterado no se descifra; el descifrado falla de forma segura | OAEP detecta manipulación; el descifrado lanza error controlado sin exponer detalles            | Prueba de dato manipulado (pentest): modificar 1 byte del texto cifrado → error genérico          |
| Disponibilidad                      | El servicio no se cae con entradas raras (vacías, enormes, no texto) | Validación de tipo y tamaño de la entrada en la API (límite de payload)                         | Pruebas de entrada vacía, muy larga (100 MB) y no texto → rechazo controlado, servicio sigue vivo |
| Autenticación                       | Solo usuarios válidos usan el servicio                               | Token JWT emitido por Keycloak y verificado en <code>auth.js</code> (firma, expiración, emisor) | Pedir /cifrar sin token → 401; con token válido (usuario demo) → 200                              |
| No repudio<br>(extra, para exceder) | Toda operación de cifrado/descifrado queda registrada                | Bitácora en <code>db.js</code> con registro de operaciones                                      | Consultar la bitácora tras una operación y verificar el registro                                  |

### Justificación de cada requisito (por qué)

**Confidencialidad.** La app móvil y el servicio se comunican por una red no confiable (Internet). Si los datos viajaran en texto plano, cualquier interceptor (sniffer, proxy, red Wi-Fi comprometida) podría leer el contenido. El cifrado RSA con OAEP garantiza que solo el poseedor de la llave privada pueda recuperar el texto original. Se eligió RSA-OAEP (no RSA sin padding ni PKCS#1 v1.5) porque

OAEP incorpora aleatoriedad y detección de manipulación, mitigando ataques de padding (Bleichenbacher).

**Integridad.** Un atacante puede interceptar y modificar el texto cifrado en tránsito. Si el descifrado no detectara la alteración, el receptor obtendría un mensaje corrupto sin saberlo (o peor, un mensaje manipulado válido). OAEP incluye verificación de integridad: si el padding no es válido, el descifrado falla de forma segura. El requisito exige que ese fallo sea **controlado** (error genérico, sin detalles internos) para no filtrar información al atacante (CWE-209).

**Disponibilidad.** Una API pública sin validación de entrada es vulnerable a DoS trivial: un payload de cientos de MB agota memoria/CPU, o una entrada malformada provoca una excepción no controlada que tumba el proceso. El requisito exige validar tipo y tamaño **antes** de procesar, y que los errores se manejen sin terminar el servicio.

**Autenticación.** El servicio de cifrado es un recurso valioso: sin control de acceso, cualquiera podría usarlo para cifrar/descifrar (abuso del servicio, consumo de recursos, o uso como oráculo de descifrado). Keycloak centraliza la identidad: emite tokens JWT firmados; el servicio solo acepta tokens válidos (firma verificada, no expirados, emisor correcto).

**No repudio (extra).** Para operaciones sensibles, debe quedar evidencia de quién hizo qué y cuándo. La bitácora permite auditoría y detección de abusos. Se documenta como requisito adicional para exceder el alcance mínimo (CIA + autenticación).

#### *Mapeo con estándares*

| Requisito        | OWASP SAMM                                           | NIST SSDF                                    | OWASP ASVS                                         | OWASP MASVS                       |
|------------------|------------------------------------------------------|----------------------------------------------|----------------------------------------------------|-----------------------------------|
| Confidencialidad | EG2 (Estrategia de seguridad) / SA-2 (Diseño seguro) | PW.6.1 (protección de datos)                 | V6 (Criptografía almacenada) / V9 (Comunicaciones) | MASVS-CRYPTO-1 (cifrado de datos) |
| Integridad       | SA-2 (Diseño seguro)                                 | PW.6.1 / PW.7.1 (verificación de integridad) | V6.2 (integridad criptográfica)                    | MASVS-CRYPTO-2 (integridad)       |
| Disponibilidad   | SM-2 (Gestión de riesgos)                            | PW.4.1 (validación de entrada)               | V5 (Validación de entrada)                         | MASVS-PLATFORM-2                  |

| Requisito     | OWASP SAMM                           | NIST SSDF                       | OWASP ASVS                       | OWASP MASVS                     |
|---------------|--------------------------------------|---------------------------------|----------------------------------|---------------------------------|
|               |                                      |                                 |                                  | (recursos)                      |
| Autenticación | EG-2 / SA-3<br>(Gestión de terceros) | PW.5.1<br>(autenticación)       | V2<br>(Autenticación)            | MASVS-AUTH-1<br>(autenticación) |
| No repudio    | SM-3<br>(Operaciones)                | RV.1.3<br>(registro de eventos) | V7 (Manejo de errores y logging) | MASVS-PRIVACY-2<br>(registro)   |

#### *Verificación cruzada con ASVS (nivel 1 — aplicable al laboratorio)*

| Requisito ASVS | Descripción                                   | Cómo se cumple                                     |
|----------------|-----------------------------------------------|----------------------------------------------------|
| 2.1.1          | Autenticación con mecanismo verificable       | JWT de Keycloak verificado en <code>auth.js</code> |
| 5.1.3          | Validación de entrada en el servidor          | Validación de tipo/tamaño en la API                |
| 6.2.1          | Cifrado con algoritmo seguro y modo apropiado | RSA-2048 OAEP-SHA256                               |
| 7.1.1          | Respuestas de error sin detalles internos     | Errores genéricos (sin stack traces)               |
| 9.1.2          | TLS en comunicaciones                         | HTTPS del Codespace / TLS en producción            |
| 12.3.1         | Cabeceras de seguridad HTTP                   | CSP, X-Frame-Options, etc. (corregido en Fase 2)   |

#### *Relación con otras secciones*

Esta tabla alimenta: informe §5, Tabla 2 (STRIDE — los controles responden a las amenazas), Tabla 5 (riesgo — los requisitos priorizan las mitigaciones) y Tabla 6 (pruebas — cada requisito tiene su prueba de verificación).

#### **Tabla 2 — Amenazas STRIDE**

Primer Avance. Modelado de amenazas con STRIDE (Microsoft): por cada amenaza, qué componente afecta, un ejemplo de ataque y cómo se frena.

## Amenazas STRIDE

| Amenaza (STRIDE)       | Componente afectado                   | Ejemplo de ataque                                                           | Control / mitigación                                                                              |
|------------------------|---------------------------------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| Spoofing (suplantar)   | API de cifrado (servidor.js, auth.js) | Usar el servicio sin identidad, o con un token falso/robado                 | Token JWT válido emitido por Keycloak y verificado (firma, expiración, emisor) en auth.js         |
| Tampering (manipular)  | Datos en tránsito (texto cifrado)     | Alterar el texto cifrado entre la app y el servicio                         | Descifrado que falla de forma segura (OAEP detecta manipulación; error controlado)                |
| Repudiation (negar)    | Servicio (db.js)                      | Negar que se hizo una operación de cifrado/descifrado                       | Bitácora y logs con registro de operaciones (quién, qué, cuándo)                                  |
| Information disclosure | Servicio / repo                       | Leer secretos en el repo (.env, llaves) o errores internos (stack traces)   | Sin secretos en el repo (variables de entorno); errores genéricos sin detalles internos (CWE-209) |
| Denial of service      | API de cifrado                        | Enviar datos enormes o malformados para agotar recursos o tumbar el proceso | Límite de tamaño de la entrada + validación de tipo antes de procesar                             |
| Elevation of privilege | Contenedor (Dockerfile)               | Ejecutar el servicio como root y escalar dentro del contenedor/host         | Contenedor sin privilegios (usuario no-root) en la imagen                                         |

## Severidad estimada por amenaza

| Amenaza   | Severidad   | Justificación                                                                                                                                                   |
|-----------|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Spoofing  | <b>Alta</b> | Sin autenticación, cualquiera usa el servicio (abuso, oráculo de descifrado). El control depende de auth.js, que en la versión insegura casi no valida el token |
| Tampering | <b>Alta</b> | La integridad es una propiedad central del                                                                                                                      |

| Amenaza                | Severidad    | Justificación                                                                                                |
|------------------------|--------------|--------------------------------------------------------------------------------------------------------------|
|                        |              | cifrado; si no se detecta manipulación, el sistema no cumple su función                                      |
| Repudiation            | <b>Media</b> | Impacto de auditoría: sin bitácora no hay evidencia de abusos, pero no compromete datos directamente         |
| Information disclosure | <b>Alta</b>  | Secretos en un repo <b>público</b> son legibles por cualquiera; errores internos facilitan ataques dirigidos |
| Denial of service      | <b>Media</b> | Impacto de disponibilidad; requiere esfuerzo del atacante pero el control (validación) es simple             |
| Elevation of privilege | <b>Media</b> | El contenedor está aislado, pero root en el contenedor amplía la superficie si hay otra vulnerabilidad       |

*Cómo se verifica cada control (prueba concreta)*

| Amenaza                | Prueba que demuestra el control                           | Resultado esperado                                           |
|------------------------|-----------------------------------------------------------|--------------------------------------------------------------|
| Spoofing               | Pedir /cifrar sin token                                   | 401 No autorizado                                            |
| Spoofing               | Pedir /cifrar con token válido (usuario demo de Keycloak) | 200 OK, cifrado correcto                                     |
| Spoofing               | Pedir /cifrar con token expirado o de firma inválida      | 401 No autorizado                                            |
| Tampering              | Modificar 1 byte del texto cifrado y pedir /descifrar     | Error controlado (400/500 genérico), sin texto corrupto      |
| Repudiation            | Realizar una operación y consultar la bitácora            | Registro presente con operación, usuario y timestamp         |
| Information disclosure | Enviar entrada inválida (ej. {} sin campo texto)          | Respuesta genérica, <b>sin</b> stack trace ni rutas internas |
| Information disclosure | Escanear el repo con Gitleaks (job secretos)              | 0 hallazgos (verde)                                          |
| Denial of service      | Enviar payload de 100 MB a /cifrar                        | Rechazado por límite de tamaño (413/400), servicio sigue     |

| Amenaza                | Prueba que demuestra el control                         | Resultado esperado        |
|------------------------|---------------------------------------------------------|---------------------------|
|                        |                                                         | respondiendo / salud      |
| Elevation of privilege | docker inspect del contenedor / whoami en el contenedor | Usuario no-root (no root) |

#### *Mapeo a CWE (para cruzar con la Tabla 3)*

| Amenaza                | CWE asociada                                                      | Hallazgo esperado en Fase 1             |
|------------------------|-------------------------------------------------------------------|-----------------------------------------|
| Spoofing               | CWE-287 (Autenticación incorrecta)                                | JWT mal validado en auth.js             |
| Tampering              | CWE-353 (Falta de verificación de integridad)                     | Descifrado sin verificación de padding  |
| Repudiation            | CWE-778 (Registro insuficiente)                                   | Bitácora ausente o incompleta           |
| Information disclosure | CWE-798 (Secretos embebidos), CWE-209 (Exposición de información) | .env con secretos; errores con detalles |
| Denial of service      | CWE-400 (Consumo de recursos)                                     | Sin límite de tamaño de entrada         |
| Elevation of privilege | CWE-250 (Ejecución con privilegios innecesarios)                  | Dockerfile con usuario root             |

#### *Relación con otras secciones*

Esta tabla alimenta: informe §6, Tabla 3 (los hallazgos de Fase 1 se clasifican por amenaza/CWE), Tabla 5 (riesgo — la severidad aquí se cuantifica con P×I) y Tabla 6 (las pruebas de verificación de esta tabla se ejecutan y documentan).

#### **Tabla 3 — Diagnóstico de seguridad (Fase 1, pipeline en rojo)**

Fuente: ejecución **35365578175** del pipeline (commit 46cb634, código oficial sin remediar), descargada de GitHub Actions. Es la única corrida que refleja el proyecto tal como llegó, antes de corregir. Reportes: EV-C204-020/021/022 (zips de archivos generados), EV-C204-027 (SBOM) y EV-C204-028 (log de los jobs en rojo); capturas de pantalla EV-C204-033 a EV-C204-051.

## Resultado por prueba

| Prueba (job)          | Resultado<br>Fase 1    | Cifras reales                                                                                | Evidencia                        |
|-----------------------|------------------------|----------------------------------------------------------------------------------------------|----------------------------------|
| SAST – Semgrep        | ✗ rojo                 | <b>23 hallazgos</b> (8 reglas distintas; 16 son de un mismo tipo en el workflow)             | EV-C204-021, captura EV-C204-040 |
| SAST – CodeQL         | ✗ rojo                 | El job avanzado falló por configuración del repositorio (no por hallazgos); ver informe §8.6 | EV-C204-047 a EV-C204-051        |
| Secretos – Gitleaks   | ✗ rojo                 | <b>4 secretos</b> en 2 archivos                                                              | EV-C204-020, captura EV-C204-041 |
| SCA – Dependencias    | ✗ rojo                 | npm audit: <b>13 vulnerabilidades</b> (3 low, 1 moderate, 8 high, <b>1 critical</b> )        | EV-C204-028                      |
| Imagen – Trivy + SBOM | ✗ rojo                 | Trivy sobre la imagen: <b>640 hallazgos</b> (583 HIGH, 57 CRITICAL)                          | EV-C204-027, EV-C204-028         |
| DAST – OWASP ZAP      | ✓ verde (solo informa) | <b>0 High, 2 Medium, 2 Low, 5 Informational</b>                                              | EV-C204-022, captura EV-C204-042 |

## Hallazgos (H-01 a H-15)

La columna **VULN** cruza con los marcadores // [VULN-n] que el código oficial trae comentados. **Confirmado** significa que una herramienta del pipeline lo reportó en la corrida 35365578175; cuando no fue así se indica cómo se identificó.

| I D  | V U L N | Prueba / herramienta | Dónde                                                           | Hallazgo y CWE                                                       | Riesgo | Confirmado en rojo |
|------|---------|----------------------|-----------------------------------------------------------------|----------------------------------------------------------------------|--------|--------------------|
| H-01 | 2       | Secretos / Gitleaks  | servidor/.env (líneas 4-5), servidor/config.js (líneas 14 y 18) | Secretos quemados: 2× aws-access-token, 2× generic-api-key (CWE-798) | Alto   | ✓ Gitleaks: 4      |

| ID   | VUL | Prueba / herramienta | Dónde                      | Hallazgo y CWE                                                                                                                | Riesgo | Confirmado en rojo                                 |
|------|-----|----------------------|----------------------------|-------------------------------------------------------------------------------------------------------------------------------|--------|----------------------------------------------------|
| H-02 | —   | SCA / npm audit      | servidor/package.json      | Dependencias vulnerables: axios 0.18.0 (CSRF, ReDoS), lodash 4.17.4 (contaminación de prototipo), otras (CWE-1104 / CWE-1035) | Alto   | ✓ 13 vulnerabilidades                              |
| H-03 | 9   | SAST / Semgrep       | servidor/servidor.js:87    | eval() sobre entrada del usuario (eval-detected) y concatenación de código (code-string-concat), CWE-95                       | Alto   | ✓ 2 reglas                                         |
| H-04 | 4   | SAST / Semgrep       | servidor/auth.js:37        | JWT aceptado sin verificar firma y con alg: none (jwt-none-alg; CWE-347 / CWE-287)                                            | Alto   | ✓                                                  |
| H-05 | 5   | DAST / ZAP           | respuestas HTTP            | CORS totalmente abierto (cors() sin lista blanca): ZAP «Cross-Domain Misconfiguration» (CWE-942)                              | Medio  | ✓ ZAP Medium                                       |
| H-06 | 8   | Revisión manual del  | servidor/servidor.js:57-69 | Se devuelve e.stack al cliente (CWE-209)                                                                                      | Medio  | ⚠ Ninguna herramienta lo reportó; identificado por |

| ID   | VULN-8 | Prueba / herramienta       | Dónde                  | Hallazgo y CWE                                                                                                                               | Riesgo | Confirmado en rojo                                           |
|------|--------|----------------------------|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|--------|--------------------------------------------------------------|
|      |        | código                     |                        |                                                                                                                                              |        | el marcador [VULN-8] y lectura del código                    |
| H-07 | 1      | Image n / Trivy            | servidor/Dockerfile    | Base node:latest no reproducible y con CVEs (CWE-1104): 640 hallazgos HIGH/CRITICAL                                                          | Alto   | ✅ Trivy                                                      |
| H-08 | 13     | SAST / Semgrep             | servidor/Dockerfile:26 | Contenedor como root (missing-user, CWE-250)                                                                                                 | Medio  | ✅                                                            |
| H-09 | 6      | DAST / ZAP                 | respuestas HTTP        | Cabeceras ausentes: «CSP: Failure to Define Directive with No Fallback» (Medium), «Permissions Policy Header Not Set» y «X-Powered-By» (Low) | Medio  | ✅ ZAP                                                        |
| H-10 | 1      | Revisión manual del código | servidor/cifrado.js    | RSA de <b>1024 bits</b> con relleno <b>PKCS#1 v1.5</b> (CWE-326 / CWE-780)                                                                   | Alto   | ⚠️ Ninguna herramienta lo reportó; identificado por [VULN-1] |
| H-11 | 3      | SAST / Semgrep             | servidor/db.js:35      | Inyección SQL por concatenación (node-mysql-sqli, CWE-89)                                                                                    | Alto   | ✅                                                            |

| ID   | VUL | Prueba                     | Dónde                                               | Hallazgo y CWE                                                                                                                                  | Riesgo | Confirmado en rojo                                                      |
|------|-----|----------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|--------|-------------------------------------------------------------------------|
|      |     |                            |                                                     |                                                                                                                                                 |        |                                                                         |
| H-12 | 1   | Image n / Trivy + SBOM     | servidor/<br>Dockerfile (COPY . .)                  | Se copia todo el contexto a la imagen (.env, llaves): CWE-538                                                                                   | Medio  | ⚠ Solo por revisión del Dockerfile; el SBOM lista los paquetes, no esto |
| H-13 | 1   | SAST / Semgrep             | servidor/<br>servidor.js:100                        | Inyección de comandos con exec('ping ...' + host) (detect-child-process, CWE-78)                                                                | Alto   | ✅                                                                       |
| H-14 | —   | SAST / Semgrep             | .github/<br>workflows/<br>devsecops.yml (16 líneas) | Acciones de GitHub con etiqueta mutable @v4/@master en vez de SHA (github-actions-mutable-action-tag; CWE-1357 / CWE-353, cadena de suministro) | Medio  | ✅ 16 hallazgos                                                          |
| H-15 | —   | SAST / Semgrep             | servidor/<br>servidor.js:24                         | Sin middleware CSRF (express-check-csurf-middleware-usage, CWE-352)                                                                             | Bajo   | ✅ (falso positivo: API sin cookies, autentica con Bearer JWT)           |
| H-16 | 7   | Revisión manual del código | servidor/<br>servidor.js:50                         | Sin validación de tipo ni tamaño de la entrada (CWE-20)                                                                                         | Medio  | ⚠ Solo por [VULN-7]                                                     |

**Reconciliación con los 23 de Semgrep:** 16 (H-14) + 1 (H-15) + 1 (H-04) + 1 (H-11) + 2 (H-03: eval-detected y code-string-concat) + 1 (H-13) + 1 (H-08) = **23**.

**Cobertura por herramienta.** El job SCA se detuvo en `npm audit` (código de salida 1) antes de ejecutar Trivy (fs), por lo que el hallazgo de dependencias de la imagen queda cubierto por H-02 y H-07. Los hallazgos H-06, H-10, H-12 y H-16 son debilidades del código oficial no reportadas por las herramientas automáticas y se identificaron mediante revisión del código, que complementa al pipeline.

### *Dónde encontrar cada hallazgo*

| Prueba       | Dónde se ve el resultado                                                                       |
|--------------|------------------------------------------------------------------------------------------------|
| sast_semgrep | Log del job en Actions + EV-C204-021-reporte-semgrep.zip (SARIF)                               |
| sast_codeql  | Pestaña <i>Security</i> → <i>Code scanning</i> (default setup); ver informe §8.6 y EV-C204-025 |
| secretos     | Log del job + EV-C204-020-reporte-gitleaks.zip (SARIF)                                         |
| sca          | Log del job (EV-C204-028)                                                                      |
| imagen       | Log del job (EV-C204-028) + SBOM (EV-C204-027)                                                 |
| dast         | EV-C204-022-reporte-zap.zip (no sale en rojo: solo informa)                                    |

### *Evidencia descargada (Fase 1)*

- ☐ Reporte Semgrep → docs/evidencias/capturas/EV-C204-021-reporte-semgrep.zip
- ☒ Reporte Gitleaks → docs/evidencias/capturas/EV-C204-020-reporte-gitleaks.zip
- ☒ SBOM → docs/evidencias/capturas/EV-C204-027-sbom-fase1.zip
- ☒ Informe ZAP → docs/evidencias/capturas/EV-C204-022-reporte-zap.zip
- ☒ Log de los jobs en rojo → docs/evidencias/capturas/EV-C204-028-log-fase1-jobs-rojos.txt (secretos de práctica redactados)
- ☒ Capturas de pantalla del pipeline en rojo → docs/evidencias/capturas/consola-git/ (EV-C204-033 a EV-C204-051)
- ☐ Captura de *Security* → *Code scanning* (Fase 1): **no existe** porque el job de CodeQL avanzado no llegó a publicar alertas; las alertas de CodeQL de la Fase 2 están en EV-C204-025.

### *Registro de confirmación*

Resumen: de 16 hallazgos, **12 fueron confirmados por una herramienta** del pipeline y **4 por revisión de código** (H-06, H-10, H-12, H-16); H-15 es un falso

positivo documentado. Ningún hallazgo esperado quedó sin evidencia de alguna de las dos fuentes.

**Tabla 4 — Evidencia antes/después (Fase 2, de rojo a verde)**

Cada fila cita el commit que corrige y la ejecución de GitHub Actions que lo comprobó. Historial completo de ejecuciones: EV-C204-029-historical-runs.txt. «Antes» = corrida 35365578175 (46cb634, ver Tabla 3). «Después» = corrida verde final **35442482331** (0fc1c11, 5/5 jobs en verde y CodeQL con 0 alertas abiertas, EV-C204-026 y EV-C204-025).

*Evidencia antes/después por hallazgo*

| Hallazgo<br>(Tabla 3)            | Prueba<br>(job) | Antes                                                                                                       | Qué se hizo para<br>corregir                                                                                       | Después                                                                                                                                              |
|----------------------------------|-----------------|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| H-01<br>Secretos quemados        | Secretos        |  4 secretos                | config.js lee solo de variables de entorno; .env fuera de git; .env.example sin valores; .gitignore (8b8b86e)      |  Gitleaks 0 (corrida 35381118104)                                 |
| H-02<br>Dependencias vulnerables | SCA             |  13 (1 critical, 8 high) | Se retiran axios, lodash y express-jwt (sin uso); express 4.22.3, jsonwebtoken 9.0.2 (8b8b86e)                     |  npm audit: 0 (corrida 35381118104)                             |
| H-03<br>eval() / H-13 exec()     | SAST Semgrep    |                          | Se eliminan los endpoints /calcular y /diagnostico (8b8b86e)                                                       |  (corrida 35389584392)                                          |
| H-04 JWT sin verificar           | SAST Semgrep    |  jwt-none-alg            | Primero jwt.verify con una sola familia de algoritmos (8b8b86e); <b>después</b> verificación real contra Keycloak: |  Semgrep 0 + 9 pruebas de token + prueba real con Keycloak 24.0 |

| Hallazgo<br>(Tabla 3)                | Prueba<br>(job)               | Antes                 | Qué se hizo para<br>corregir                                                                                                                                                                                                           | Después                                                                                                                              |
|--------------------------------------|-------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| H-05 CORS<br>abierto                 | DAST<br>ZAP                   | ✗ Medium              | RS256 + JWKS,<br>azp/aud, exp<br>(8b9b0b6, FIX de<br>autenticación)<br><br>CORS con lista<br>blanca de orígenes<br>(ORIGENES_PERMITI<br>DOS) (8b8b86e)                                                                                 | ✓ (ZAP 0 High;<br>CORS sin cabecera<br>para orígenes no<br>permitidos, EV-<br>C204-023)                                              |
| H-06<br>Errores<br>internos          | Revisi<br>ón de<br>códig<br>o | ⚠ stack al<br>cliente | Respuesta genérica<br>{ "error": "Error<br>interno" }; el<br>detalle queda en la<br>bitácora del<br>servidor (8b8b86e;<br>bitácora en<br>a81aa5f)                                                                                      | ✓ P-05 (EV-C204-<br>023)                                                                                                             |
| H-07<br>Imagen<br>latest con<br>CVEs | Image<br>n<br>Trivy           | ✗ 640 (57 crit.)      | Base fija node:20-<br>bookworm-slim<br>(8b8b86e), luego<br>node:22 (5a9c481,<br>no bastó) y por fin<br><b>multi-stage</b><br><b>node:24-trixie-</b><br><b>slim + apt</b><br><b>upgrade + sin npm</b><br><b>en runtime</b><br>(f3f9ab4) | ✓ Trivy 0 con --<br>ignore-unfixed<br>(corrida<br>35390161512);<br>riesgo residual de<br>util-linux<br>documentado<br>(informe §8.5) |
| H-08<br>Contenedo<br>r root          | Image<br>n /<br>Sems<br>rep   | ✗ missing-<br>user    | USER node<br>(8b8b86e)                                                                                                                                                                                                                 | ✓ (corrida<br>35389584392)                                                                                                           |
| H-09<br>Cabeceras<br>ausentes        | DAST<br>ZAP                   | ✗ 2 Medium, 2<br>Low  | Helmet (8b8b86e);<br>Permissions-<br>Policy manual                                                                                                                                                                                     | ✓ ZAP 0 High, 1<br>Medium (falso<br>positivo en 404), 0                                                                              |

| Hallazgo<br>(Tabla 3)                          | Prueba<br>(job)           | Antes                       | Qué se hizo para<br>corregir                                                                                                                             | Después                                  |
|------------------------------------------------|---------------------------|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|
|                                                |                           |                             | (0f5da25); X-<br>Powered-By<br>desaparece con<br>Helmet                                                                                                  | Low                                      |
| H-10<br>Cripto<br>débil                        | Revisión de<br>código     | ⚠ RSA-1024 +<br>PKCS#1 v1.5 | RSA-2048 + OAEP<br>(8b8b86e); <b>OAEP<br/>con SHA-256<br/>explícito</b><br>(a81aa5f)                                                                     | ✅ 3 pruebas<br>(oaep.test.js)            |
| H-11 SQL<br>injection                          | SAST<br>Semgrep           | ❌ node-mysql-<br>sqli       | Consulta<br>parametrizada ?<br>(8b8b86e)                                                                                                                 | ✅ (corrida<br>35389584392)               |
| H-12<br>COPY . .                               | Revisión de<br>Dockerfile | ⚠                           | Copia selectiva de<br>archivos; .dockeri<br>gnore (8b8b86e,<br>8b9b0b6)                                                                                  | ✅                                        |
| H-14<br>Acciones<br>con<br>etiqueta<br>mutable | SAST<br>Semgrep           | ❌ 16                        | Acciones fijadas a<br>SHA completo<br>(cc759ad)                                                                                                          | ✅ (corrida<br>35389584392)               |
| H-15 CSRF<br>(falso<br>positivo)               | SAST<br>Semgrep           | ❌ 1                         | nosemgrep en la<br>misma línea, con<br>justificación<br>(cc759ad, 657ac2f)                                                                               | ✅ 1 suprimido en<br>el código, 0 activos |
| H-16 Sin<br>validación                         | Revisión de<br>código     | ⚠                           | Validación de tipo<br>y longitud; cuerpo<br>máx. 10 KB<br>(8b8b86e); límite<br>en <b>bytes</b> igual a la<br>capacidad de RSA-<br>OAEP, 190<br>(0fc1c11) | ✅ P-06, P-07, P-<br>07b, P-07c, P-08     |
| (nuevo) Sin                                    | SAST                      | ❌ 3 alertas                 | express-rate-                                                                                                                                            | ✅ CodeQL: 0                              |

| Hallazgo<br>(Tabla 3)   | Prueba<br>(job) | Antes                                       | Qué se hizo para<br>corregir                           | Después                              |
|-------------------------|-----------------|---------------------------------------------|--------------------------------------------------------|--------------------------------------|
| límite de<br>peticiones | Code<br>QL      | <i>high</i><br>js/missing-<br>rate-limiting | limit: 100<br>peticiones/min por<br>IP → 429 (500b39c) | abiertas, 3 «fixed»<br>(EV-C204-025) |

### Registro de commits de remediación (trazabilidad)

| Com<br>mit  | Mensaje (resumen)                                             | Corrige                                     | Resultado en Actions                               |
|-------------|---------------------------------------------------------------|---------------------------------------------|----------------------------------------------------|
| 46cb<br>634 | devcontainer sin docker-<br>in-docker                         | <i>(base de la Fase 1)</i>                  | corrida<br>35365578175 (Fase 1)                    |
| 8b8b<br>86e | Remediación del<br>servidor: 13 hallazgos<br>SAST             | H-01...H-13, H-16                           | Gitleaks  SCA<br>Imagen/ZAP  (ver<br>siguiente)    |
| e267<br>ad5 | Quita COPY public (error<br>introducido al remediar)          | Build de la imagen                          | ZAP ; Imagen<br>(CVEs)                             |
| 5a9c<br>481 | Base node:22-bookworm-<br>slim                                | H-07 (intento)                              | no cerró los CVEs<br>de util-linux                 |
| cc75<br>9ad | Acciones a SHA completo<br>+ nosemgrep CSRF                   | H-14, H-15                                  | Semgrep  (corrida<br>35389584392)                  |
| f3f9<br>ab4 | Multi-stage node:24-<br>trixie-slim, quita<br>CodeQL avanzado | H-07                                        | 5/5  ( <b>corrida</b><br><b>35390161512</b> )      |
| 0f5d<br>a25 | Permissions-Policy                                            | H-09 (Low de ZAP)                           | Semgrep<br>(escaneaba docs/);<br>resto             |
| 657a<br>c2f | Semgrep excluye docs/;<br>nosemgrep inline                    | H-15                                        | 5/5  ( <b>corrida</b><br><b>35405835472</b> )      |
| 8b9b<br>0b6 | Autenticación RS256 +<br>JWKS de Keycloak;<br>.dockerignore   | H-04 (real con<br>Keycloak), H-12           | Semgrep (jwt-<br>hardcode en la<br>prueba)         |
| c27d<br>28d | Secreto aleatorio en la<br>prueba HS256                       | <i>(corrección de mi<br/>propia prueba)</i> | 5/5 (corrida<br>35441709157);<br>CodeQL: 3 alertas |
| 500b<br>39c | Límite de peticiones por<br>IP                                | Alertas CodeQL                              | 5/5 (corrida<br>35441885522);                      |

| Com<br>mit  | Mensaje (resumen)                                          | Corrige                                        | Resultado en Actions                                  |
|-------------|------------------------------------------------------------|------------------------------------------------|-------------------------------------------------------|
|             |                                                            |                                                | CodeQL 0                                              |
| a81a<br>a5f | OAEP-SHA256 y bitácora de operaciones                      | H-10, H-06, no repudio                         | ✓ 5/5 (corrida 35442133748); CodeQL 0                 |
| 0fc1<br>c11 | Límite de entrada = capacidad real de RSA-OAEP (190 bytes) | H-16 (defecto hallado en las pruebas de borde) | ✓ 5/5 ( <b>corrida 35442482331</b> ); <b>CodeQL 0</b> |

Cada corrección constituye un commit independiente, con mensaje descriptivo y la ejecución que lo verifica, conforme a la rúbrica («Pruebas y ajustes de código»). Los commits e267ad5, 5a9c481, 0f5da25 y 8b9b0b6 corresponden a ajustes intermedios dentro del ciclo *encontrar* → *corregir* → *volver a probar*.

### Tabla 5 — Cálculo de riesgo

Probabilidad e impacto se calcularon con los hallazgos confirmados de la Fase 1 (Tabla 3), y el riesgo residual con la evidencia de la ejecución 35442482331 (Tabla 4). Los valores de P e I corresponden a una valoración fundamentada del equipo con la escala indicada; no son mediciones.

### Metodología

Riesgo = **Probabilidad** × **Impacto**, con escala documentada:

| Nivel     | Probabilidad (P)                                | Impacto (I)                                     |
|-----------|-------------------------------------------------|-------------------------------------------------|
| Bajo (1)  | Poco probable (requiere condiciones especiales) | Impacto menor, sin datos sensibles              |
| Medio (2) | Posible (requiere algún esfuerzo)               | Impacto moderado, datos parciales               |
| Alto (3)  | Probable (bajo esfuerzo, herramientas comunes)  | Impacto grave, datos sensibles o servicio caído |

**Nivel de riesgo:** Bajo (1–2) · Medio (3–4) · Alto (6–9)

*Registro de riesgos: antes y después de corregir*

| ID   | Vulnerabilidad<br>(Tabla 3)       | P<br>antes | I | Ri<br>es<br>go<br>an<br>tes | Ni<br>vel | P<br>des<br>pué<br>s | Rie<br>sgo<br>des<br>pu<br>és | Ni<br>vel | Base de la reducción                                                                                                        |
|------|-----------------------------------|------------|---|-----------------------------|-----------|----------------------|-------------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------|
| R-01 | Secretos quemados (H-01)          | 3          | 3 | 9                           | Alto      | 1                    | 3                             | Medio     | Gitleaks 0. Sigue Medio porque los valores ya estuvieron en el historial de git: en un caso real habría que <b>rotarlos</b> |
| R-02 | Dependencias vulnerables (H-02)   | 3          | 3 | 9                           | Alto      | 1                    | 3                             | Medio     | npm audit: 0                                                                                                                |
| R-03 | eval() / exec() (H-03, H-13)      | 2          | 3 | 6                           | Alto      | 1                    | 3                             | Medio     | Endpoints eliminados (404, EV-C204-023); P mínima, I se mantiene                                                            |
| R-04 | JWT mal validado (H-04)           | 3          | 3 | 9                           | Alto      | 1                    | 3                             | Medio     | RS256 + JWKS; 9 pruebas unitarias y 23 comprobaciones contra Keycloak real                                                  |
| R-05 | CORS abierto (H-05)               | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | Lista blanca (EV-C204-023)                                                                                                  |
| R-06 | Errores internos expuestos (H-06) | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | Error genérico                                                                                                              |
| R-07 | Imagen con CVEs (H-07)            | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | Trivy 0 con --ignore-unfixed;<br><b>residual:</b> util-linux sin parche                                                     |
| R-08 | Contenedor como root (H-08)       | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | USER node (verificado: el                                                                                                   |

| ID   | Vulnerabilidad<br>(Tabla 3)              | P<br>antes | I | Ri<br>es<br>go<br>an<br>tes | Ni<br>vel | P<br>des<br>pué<br>s | Rie<br>sgo<br>des<br>pu<br>és | Ni<br>vel | Base de la reducción           |
|------|------------------------------------------|------------|---|-----------------------------|-----------|----------------------|-------------------------------|-----------|--------------------------------|
|      | 08)                                      |            |   |                             | io        |                      |                               |           | contenedor corre<br>como node) |
| R-09 | Cabeceras ausentes (H-09)                | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | ZAP: 0 High, 0 Low             |
| R-10 | Criptografía insegura (H-10)             | 2          | 3 | 6                           | Alto      | 1                    | 3                             | Medio     | RSA-2048 + OAEP-SHA256         |
| R-11 | Inyección SQL (H-11)                     | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | Consulta parametrizada         |
| R-12 | Cadena de suministro del pipeline (H-14) | 2          | 2 | 4                           | Medio     | 1                    | 2                             | Bajo      | Acciones fijadas a SHA         |
| R-13 | Abuso / fuerza bruta sin límite (CodeQL) | 3          | 2 | 6                           | Alto      | 1                    | 2                             | Bajo      | 429 al superar 100/min         |

**Resumen** (suma de la columna de riesgo): antes = 9+9+6+9+4+4+4+4+4+6+4+4+6 = **73**; después = 3+3+3+3+2+2+2+2+2+3+2+2+2 = **31**. Reducción =  $(73-31)/73 \approx 58\%$ . Riesgos en nivel Alto: **de 6 a 0**. Ningún riesgo llega a 1 porque el impacto potencial del activo no cambia con la corrección; solo baja la probabilidad.

### *Análisis gerencial complementario*

#### *Pérdida anual esperada (ALE)*

ALE = SLE × ARO, donde SLE = AV × EF (valor del activo × factor de exposición) y ARO = tasa anual de ocurrencia.

| Activo             | Valor<br>(AV) | Factor de<br>exposición<br>(EF) | SLE    | ARO<br>antes | ALE<br>antes  | ARO<br>despu<br>és | ALE<br>despu<br>és |
|--------------------|---------------|---------------------------------|--------|--------------|---------------|--------------------|--------------------|
| Datos cifrados por | \$10,0        | 0.5                             | \$5,00 | 2            | <b>\$10,0</b> | 0.5                | <b>\$2,50</b>      |

| Activo                              | Valor (AV) | Factor de exposición (EF) | SLE     | ARO antes | ALE antes       | ARO después | ALE después    |
|-------------------------------------|------------|---------------------------|---------|-----------|-----------------|-------------|----------------|
| el servicio                         | 00         |                           | 0       |           | <b>00</b>       |             | <b>0</b>       |
| Llaves RSA del servicio             | \$20,000   | 0.3                       | \$6,000 | 1         | <b>\$6,000</b>  | 0.25        | <b>\$1,500</b> |
| Credenciales de usuarios (Keycloak) | \$15,000   | 0.4                       | \$6,000 | 1         | <b>\$6,000</b>  | 0.25        | <b>\$1,500</b> |
| Disponibilidad del servicio         | \$8,000    | 0.5                       | \$4,000 | 3         | <b>\$12,000</b> | 1           | <b>\$4,000</b> |
| <b>Total ALE</b>                    |            |                           |         |           | <b>\$34,000</b> |             | <b>\$9,500</b> |

Los valores monetarios son **ilustrativos** para el laboratorio académico (no hay un negocio real detrás) y se ajustarían con datos del contexto si el docente lo solicita. La tasa ARO «después» es una estimación del equipo tras los controles verificados.

#### Justificación de probabilidades

- **R-01 (secretos):** P=3 antes: el repositorio es público y cualquiera puede leer los valores sin esfuerzo (Gitleaks los detectó con reglas estándar). Impacto 3: compromete credenciales y llaves.
- **R-02 (dependencias):** P=3: las herramientas de explotación de CVEs conocidos son públicas y automatizadas; había 1 crítica y 8 altas.
- **R-04 (JWT):** P=3: sin validación de firma, cualquier token falso era aceptado; explotarlo era trivial. Impacto 3: acceso total al servicio.
- **R-03 (eval):** P=2: requiere que la entrada llegue al endpoint; impacto 3 (ejecución de código).
- **R-10 (criptografía):** P=2: explotar padding débil requiere conocimiento especializado; impacto 3 (descifrado de datos).
- **R-13 (rate limiting):** P=3: cualquiera puede repetir peticiones sin límite; impacto 2 (abuso del servicio como oráculo o saturación).

#### Priorización y decisiones

El orden de corrección de la Fase 2 siguió la prioridad de esta tabla: primero los riesgos **Altos** (R-01, R-02, R-04, R-03, R-10) y luego los **Medios** (R-05 a R-09, R-11, R-

12); R-13 apareció al revisar las alertas de CodeQL del run verde y se cerró después. Ver docs/remediacion-playbook.md.

### Riesgo residual aceptado

1. **CVEs de util-linux sin parche** en la imagen base (CVE-2026-53613, 76642, 78408, 78409, 78410): no existe versión corregida; se excluyen del fallo con `--ignore-unfixed` y se documentan en el informe §8.5. Acción: re-escanear periódicamente.
2. **Falso positivo de ZAP** «CSP: Failure to Define Directive with No Fallback» en respuestas 404 (informe §12.4).
3. **Secretos históricos**: los valores de práctica siguen en el historial de git; son ficticios. En un proyecto real habría que rotarlos y reescribir el historial.

### Relación con otras secciones

Esta tabla alimenta: informe §16, la plantilla de diagnóstico y la Tabla 4.

### Tabla 6 — Documentación de pruebas

Las pruebas funcionales se ejecutaron contra un **Keycloak 24.0 real** (contenedor Docker local, no el del Codespace) y el servicio del commit `0fc1c11`. Reproducible con `bash scripts/prueba-e2e-keycloak.sh`. Evidencia: EV-C204-023-pruebas-e2e-keycloak.txt (25 comprobaciones, 25 pasan) y EV-C204-024-pruebas-unitarias.txt (22 pruebas Jest, ESLint sin advertencias, `npm audit 0`).

### Pruebas funcionales del servicio

| ID   | Prueba                  | Datos de entrada                            | Resultado esperado     | Resultado real                              | Estado |
|------|-------------------------|---------------------------------------------|------------------------|---------------------------------------------|--------|
| P-01 | Cifrar texto            | "Hola mundo"                                | Texto cifrado (base64) | 200; base64 de 344 caracteres (E/GIi+WZ...) | ✓      |
| P-02 | Descifrar texto         | Texto cifrado de P-01                       | "Hola mundo"           | 200; {"descifrado": "Hola mundo"}           | ✓      |
| P-03 | Cifrar con token válido | Token RS256 real de Keycloak (usuario demo) | 200 OK                 | 200                                         | ✓      |

| ID    | Prueba                       | Datos de entrada                                                              | Resultado esperado   | Resultado real                                           | Estado |
|-------|------------------------------|-------------------------------------------------------------------------------|----------------------|----------------------------------------------------------|--------|
| P-04  | Cifrar sin token             | Sin cabecera Authorization                                                    | 401 No autorizado    | 401                                                      | ✓      |
| P-05  | Descifrar dato manipulado    | Texto cifrado con 1 carácter alterado                                         | Error controlado     | 500 con {"error": "Error interno"} (sin pila ni detalle) | ✓      |
| P-06  | Entrada vacía                | ""                                                                            | Error de validación  | 400                                                      | ✓      |
| P-07  | Entrada muy larga            | 20 KB (el límite del cuerpo es 10 KB)                                         | Rechazado por límite | 413                                                      | ✓      |
| P-07b | Borde del máximo de RSA      | 190 bytes                                                                     | Se cifra             | 200                                                      | ✓      |
| P-07c | Justo sobre el máximo        | 191 bytes                                                                     | Rechazo controlado   | 400 (antes de FIX-22 daba 500)                           | ✓      |
| P-08  | Entrada no texto             | 12345 (número)                                                                | Error de tipo        | 400                                                      | ✓      |
| P-09  | /salud                       | —                                                                             | {"estado": "ok"}     | 200; {"estado": "ok", "version": "remediado-2.0"}        | ✓      |
| P-10  | Descifrar con token expirado | Token de Keycloak con vida de 5 s, usado tras 12 s (tolerancia de reloj: 5 s) | 401                  | 401                                                      | ✓      |
| P-10b | Token de otro cliente        | Token válido del cliente otra-app (mismo realm)                               | 401                  | 401                                                      | ✓      |
| P-25  | Ida y vuelta                 | Ñandú 😊 + salto de línea                                                      | Texto idéntico       | 200 / 200; texto recuperado idéntico                     | ✓      |

| ID | Prueba    | Datos de entrada | Resultado esperado | Resultado real | Estado |
|----|-----------|------------------|--------------------|----------------|--------|
|    | con UTF-8 |                  |                    |                |        |

#### Pruebas del pipeline (GitHub Actions)

| ID   | Job                   | Resultado Fase 1 (run 35365578175) | Resultado Fase 2 (run 35442482331)                                         | Evidencia                 |
|------|-----------------------|------------------------------------|----------------------------------------------------------------------------|---------------------------|
| P-11 | SAST – Semgrep        | ✗ 23 hallazgos                     | ✓ 0 activos (1 falso positivo suprimido en el código)                      | EV-C204-021 / EV-C204-008 |
| P-12 | SAST – CodeQL         | job avanzado ✗ por configuración   | ✓ default setup: 0 alertas abiertas (3 de <i>rate limiting</i> corregidas) | EV-C204-025               |
| P-13 | Secretos – Gitleaks   | ✗ 4 secretos                       | ✓ 0                                                                        | EV-C204-020 / EV-C204-009 |
| P-14 | SCA – Dependencias    | ✗ 13 vulnerabilidades              | ✓ 0                                                                        | EV-C204-028 / EV-C204-024 |
| P-15 | Imagen – Trivy + SBOM | ✗ 640 hallazgos                    | ✓ 0 (--ignore-unfixed; residual util-linux)                                | EV-C204-027 / EV-C204-010 |
| P-16 | DAST – OWASP ZAP      | informe: 2 Medium, 2 Low           | informe: 0 High, 1 Medium (falso positivo), 0 Low                          | EV-C204-022 / EV-C204-011 |

#### Pruebas de pentest (manual)

| ID   | Prueba                        | Técnica                    | Resultado esperado | Resultado real                           | Hallazgo |
|------|-------------------------------|----------------------------|--------------------|------------------------------------------|----------|
| P-17 | Manipulación de texto cifrado | Alterar 1 carácter         | Error controlado   | 500 genérico, servicio sigue vivo (P-23) | Ninguno  |
| P-18 | Token inválido                | Firma de otra llave RS256; | 401                | 401 en los 6 casos (4 en EV-             | Ninguno  |

| I<br>D       | Prueba                                                 | Técnica                                                                                   | Resultado<br>esperado               | Resultado real                                                                                                                                                                           | Hallazgo              |
|--------------|--------------------------------------------------------|-------------------------------------------------------------------------------------------|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|
| 8            |                                                        | HS256;<br>alg:none; token<br>real con la firma<br>alterada; kid<br>desconocido;<br>basura |                                     | C204-023; kid y<br>basura en las<br>pruebas Jest)                                                                                                                                        |                       |
| P-<br>1<br>9 | Cabeceras<br>de<br>seguridad                           | curl -I /salud                                                                            | Cabeceras<br>presentes              | CSP, X-Frame-<br>Options, X-<br>Content-Type-<br>Options, HSTS,<br>Referrer-<br>Policy, Cross-<br>Origin-Opener-<br>Policy,<br>Permissions-<br>Policy<br>presentes; sin X-<br>Powered-By | Ninguno               |
| P-<br>2<br>0 | CORS                                                   | Origen no<br>permitido<br>(http://malo.e<br>xample)                                       | Sin<br>cabecera<br>CORS             | 0 cabeceras<br>Access-<br>Control-Allow-<br>Origin; el origen<br>permitido sí la<br>recibe                                                                                               | Ninguno               |
| P-<br>2<br>1 | Fuerza<br>bruta /<br>abuso                             | 130 peticiones<br>seguidas                                                                | Rate<br>limiting o<br>401           | 76 × 200 y 54 ×<br>429 (límite<br>100/min;<br>contando<br>peticiones<br>previas)                                                                                                         | Corregido<br>(FIX-19) |
| P-<br>2<br>3 | Disponibili<br>dad tras<br>entradas<br>malformad<br>as | JSON roto {{{{                                                                            | /salud<br>sigue<br>respondie<br>ndo | 200                                                                                                                                                                                      | Ninguno               |
| P-<br>2      | No repudio                                             | Operación de<br>cifrado                                                                   | Queda<br>registrada                 | Línea JSON con<br>ts, accion,                                                                                                                                                            | Corregido<br>(FIX-21) |

| ID   | Prueba                                 | Técnica            | Resultado esperado  | Resultado real                                    | Hallazgo                                             |
|------|----------------------------------------|--------------------|---------------------|---------------------------------------------------|------------------------------------------------------|
| 4    |                                        |                    | sin datos sensibles | resultado, usuario, ip; el texto plano no aparece |                                                      |
| P-26 | Confusión de algoritmo / capacidad RSA | Texto de 191 bytes | Rechazo controlado  | 400                                               | <b>Encontrado y corregido (FIX-22):</b><br>antes 500 |

#### Pruebas automatizadas del servicio (npm test)

| ID    | Suite               | Casos                                                                                                | Resultado                 |
|-------|---------------------|------------------------------------------------------------------------------------------------------|---------------------------|
| P-22  | cifrado.test.js     | 3 (round-trip, PEM, texto distinto del original)                                                     | ✓ 3 pasan                 |
| P-22b | integracion.test.js | 6 (/salud, /llave, ciclo completo, bitácora, borde 190/191, bytes UTF-8)                             | ✓ 6 pasan                 |
| P-22c | auth.test.js        | 9 (sin token, válido, expirado, firma ajena, HS256, alg:none, otro cliente, kid desconocido, basura) | ✓ 9 pasan                 |
| P-22d | oaep.test.js        | 3 (OAEP-SHA256, no SHA-1, llave 2048 bits)                                                           | ✓ 3 pasan                 |
| P-22e | limite.test.js      | 1 (429 al superar el límite)                                                                         | ✓ 1 pasa                  |
|       | <b>Total</b>        | <b>22 (la guía pedía 6: Tests: 6 passed)</b>                                                         | <b>✓ Tests: 22 passed</b> |

#### Ajustes de pruebas realizados

Estos son los ajustes que **se hicieron y verificaron** para cubrir más casos de uso (criterio «Pruebas y ajustes de código» de la rúbrica):

1. **P-10 ampliada:** no solo token expirado, sino también firma inválida, HS256, alg:none, kid desconocido, token de otro cliente y token expirado **de Keycloak real** (con vida de 5 s).
2. **P-07 ampliada con el borde real:** 190 bytes (pasa) y 191 bytes (rechazo). Al hacerlo se **descubrió un defecto:** textos de más de 190 bytes producían

500; se corrigió (FIX-22) y se probó también contando bytes UTF-8 (emojis de 4 bytes).

3. **P-23 agregada:** disponibilidad tras JSON malformado.
4. **P-24 agregada:** no repudio (bitácora sin texto plano).
5. **P-25 agregada:** ida y vuelta con UTF-8, emoji y salto de línea.
6. **Corrección de una prueba defectuosa:** la primera versión de «token con la firma alterada» cambiaba el **último** carácter de la firma y a veces daba 200; en base64 los últimos bits del último carácter no cambian los bytes. Se cambió a alterar un carácter central y se repitió 3 veces seguidas (23/23 cada vez).
7. **Sensibilidad al reloj:** la primera prueba de expiración esperó 8 s con tokens de 5 s y aceptó el token, porque el servicio tolera 5 s de desfase de reloj. No era un fallo del servicio: se ajustó la espera a 12 s.

#### *Pruebas ejecutadas por el equipo en el Codespace*

| ID   | Prueba                                                            | Datos de entrada                                                                  | Resultado                      |                                                                                                                                                     | Estado |
|------|-------------------------------------------------------------------|-----------------------------------------------------------------------------------|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|--------|
|      |                                                                   |                                                                                   | esperado                       | Resultado real                                                                                                                                      |        |
| P-27 | Cifrar/descifrar desde la <b>app móvil</b> (Expo) en el Codespace | Texto «Hola CIB-204», URL pública del puerto 3000, sin token (AUTH_ENABLED=false) | Cifrado y descifrado correctos | «Descifrado OK»: la app mostró el cifrado en base64 y recuperó «Hola CIB-204» (EV-C204-006)                                                         | ✓      |
| P-28 | Keycloak en el <b>Codespace</b> (consola web)                     | Usuario demo en el realm appmovil                                                 | Usuario creado y habilitado    | Realm appmovil, cliente servicio-cifrado y usuario demo habilitado con email verificado, todos en la consola del Codespace (EV-C204-003, 004 y 005) | ✓      |

**Observación sobre EV-C204-005:** el usuario aparece con la acción requerida «**Update Password**». Con esa acción pendiente, demo **no puede**

**obtener un token** por contraseña directa (Keycloak exige cambiar la clave primero). La prueba de la app (P-27) no lo necesita porque se hizo con el acceso apagado. Para probar la app **con token** hay que quitar esa acción del usuario (campo «Required user actions») o crear la contraseña con «Temporary» desactivado.

## Relación con otras secciones

Esta tabla alimenta: informe §17, la plantilla de diagnóstico y la verificación de los requisitos de la Tabla 1 (cada requisito tiene su prueba aquí).

### Anexo B — Reportes del pipeline

| Reporte          | Fase 1 (rojo, run 35365578175)                             | Fase 2 (verde, run 35442482331)                                                      |
|------------------|------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Semgrep (SARIF)  | EV-C204-021-reporte-semgrep.zip: 23 hallazgos              | EV-C204-008-semgrep.json: 1 resultado, suprimido en el código (CSRF, falso positivo) |
| Gitleaks (SARIF) | EV-C204-020-reporte-gitleaks.zip: 4 secretos               | EV-C204-009-gitleaks.json: 0                                                         |
| SBOM (SPDX)      | EV-C204-027-sbom-fase1.zip (imagen node:latest)            | EV-C204-010-sbom.json (imagen multi-stage node:24-trixie-slim)                       |
| ZAP (HTML)       | EV-C204-022-reporte-zap.zip: 2 Medium, 2 Low               | EV-C204-011-zap.html: 1 Medium (falso positivo), 0 Low                               |
| CodeQL           | job avanzado en rojo (configuración, §8.6)                 | EV-C204-025-codeql-alertas.json: 0 abiertas, 3 corregidas                            |
| Log de los jobs  | EV-C204-028-log-fase1-jobs-rojos.txt (secretos redactados) | EV-C204-026-run-verde.txt                                                            |

Todos los reportes de la Fase 2 son **byte-idénticos** a los archivos generados del run 35442482331 (bash scripts/verificar-evidencia.sh 35442482331). Los tres zips de la Fase 1 son idénticos a los archivos generados del run 35365578175, cuya huella SHA-256 se ve en la captura EV-C204-038.

## Anexo C — Manifiesto SHA-256

docs/evidencias/manifiesto-sha256.txt registra el SHA-256 de cada archivo de evidencia, del informe (.md, .docx y .pdf), de las tablas, del workflow y de los scripts. Se verifica **desde la raíz del repositorio**:

```
sha256sum --check docs/evidencias/manifiesto-sha256.txt # esperado: todos «OK»
```

Se regenera con `bash scripts/generar-manifiesto.sh` después de cualquier cambio en esos archivos. El manifiesto no puede incluirse a sí mismo.

---

## Anexo D — Historial de versiones del repositorio

Commits hasta 0fc1c11 (el código evaluado); los posteriores solo cambian documentación y evidencia. El listado completo de ejecuciones del pipeline está en EV-C204-029.

| Commit  | Fecha      | Mensaje                                                                                                                     |
|---------|------------|-----------------------------------------------------------------------------------------------------------------------------|
| a20bf16 | 2026-09-17 | Estructura inicial del proyecto DevSecOps CIB-204: documentación, tablas, evidencias, pipeline y entorno                    |
| 8129154 | 2026-09-17 | Plan de acción 100% rúbrica + datos del curso validados                                                                     |
| 3441e89 | 2026-09-17 | Repo privado durante el desarrollo; público al finalizar (CodeQL)                                                           |
| e15ebce | 2026-09-17 | Avance sin zip: validación de objetivos, Tablas 1-2 completas, Parte I del informe, figuras SVG, playbook de remediación... |
| 82c3bbe | 2026-09-17 | Avance sin zip (2): Parte II del informe (diseño RSA/JWT/pipeline), Tablas 3-5-6 pre-llenadas, casos de abuso, invent...    |
| 9b1bddb | 2026-09-17 | Integra material oficial (zip CIB-204 §17): 13 vulnerabilidades reales VULN-1..13 con CWE (RSA-PKCS1/1024, .env con A...    |
| 9a63eb8 | 2026-09-17 | Anexo F cierre §17: informe maestro renderizado en PDF (15 pag, pdflatex limpio) y DOCX con acentos ok; manifiesto SH...    |

| Commit  | Fecha      | Mensaje                                                                                                                  |
|---------|------------|--------------------------------------------------------------------------------------------------------------------------|
| 46cb634 | 2026-09-18 | devcontainer: quita docker-in-docker (causa recovery-mode en plan gratis 2-core); pasa a imagen Node 20 ligera para a... |
| 8b8b86e | 2026-09-18 | remediacion(servidor): cierra 13 hallazgos SAST para pipeline verde Fase 2                                               |
| e267ad5 | 2026-09-18 | fix(imagen): quita COPY public residuo que rompe el build (Trivy+ZAP+SBOM en cascada)                                    |
| 5a9c481 | 2026-09-18 | fix(imagen): base node:22-bookworm-slim cierra CVE-2026-76642/76643 de Trivy (util-linux 2.40 parchado)                  |
| e028d74 | 2026-09-18 | docs(informe): §8 documenta correccion del Dockerfile (COPY public no era del zip) y CodeQL default setup                |
| cc759ad | 2026-09-18 | fix(pipeline): fija acciones a SHA completo (16 hallazgos supply chain Semgrep) y suprime falso positivo CSRF (API JW... |
| f3f9ab4 | 2026-09-18 | fix(imagen): multi-stage node:24-trixie-slim + apt upgrade + quita npm del runtime; Trivy 0 hallazgos con --ignore-un... |
| b0115df | 2026-09-18 | docs(informe): §8.5/§8.6 y playbook DoD actualizados con pipeline verde (5 jobs + CodeQL default setup) y riesgo resi... |
| 0f5da25 | 2026-09-18 | fix(servidor): FIX-17 Permissions-Policy (camera/mic/geo/payment/usb=()) cierra hallazgo Low de ZAP 'Permissions Poli... |
| 657ac2f | 2026-09-18 | fix(servidor): FIX-18 excluye docs/ del SAST Semgrep (.semgrepignore + --exclude) y pasa CSRF a nosemgrep inline en s... |
| 6112c42 | 2026-09-18 | docs(evidencias): manifiesto SHA-256 canónico regenerado y coincidente con los 4 EV descargados del run verde 3540583... |
| 26fd547 | 2026-09-18 | docs(evidencias): EV-C204-018..051 — evidencia completa del cierre FIX-18: PPT/PDF de la consola Git del usuario + 19... |
| 98236ec | 2026-09-18 | fix(evidencias): FIX-18 — convergencia byte-                                                                             |

| Commit  | Fecha      | Mensaje                                                                                                                  |
|---------|------------|--------------------------------------------------------------------------------------------------------------------------|
| 0e88570 | 2026-09-18 | exacta de EV-C204-010 (sbom) y EV-C204-011 (zap.html) con los artefactos ...                                             |
| fb706cb | 2026-09-18 | docs(evidencias): FIX-18 cierre — EV-C204-010 sbom y EV-C204-011 zap re-instalados byte-exactos desde el run verde 35... |
| 77c1964 | 2026-09-18 | docs(informe): FIX-18 cierre — cito tus 19 slides EV-C204-033..051 individualmente en §12.6 del informe, cada una en ... |
| 86ff781 | 2026-09-19 | docs(evidencias): FIX-18 cierre — Anexo I con las 19 capturas de consola Git individualizadas EV-C204-033..051 (hashe... |
| 8b9b0b6 | 2026-09-19 | docs(auditoria): INSTRUCCIONES-AUDITORIA-AI.md — handoff autocontenido para auditoría externa por IA: qué/cómo/por-qu... |
| c27d28d | 2026-09-19 | fix(auth): valida tokens de Keycloak con RS256 + JWKS (guia 10.5, informe 11.2)                                          |
| 500b39c | 2026-09-19 | test(auth): secreto HS256 aleatorio en la prueba (Semgrep jwt-hardcode lo marcaba como credencial fija)                  |
| a81aa5f | 2026-09-19 | fix(servidor): FIX-19 limite de peticiones por IP (CodeQL js/missing-rate-limiting)                                      |
| 125d455 | 2026-09-19 | fix(servidor): FIX-20 OAEP-SHA256 explicito y FIX-21 bitacora de operaciones                                             |
| 0fc1c11 | 2026-09-19 | test(e2e): altera un caracter central de la firma (el ultimo caracter base64 no cambia los bytes)                        |
|         | 2026-09-19 | fix(servidor): FIX-22 limite de entrada = capacidad real de RSA-OAEP (190 bytes)                                         |

## Anexo E — Cronograma del proyecto

| Semana | Actividad                                                 | Entregable        | Estado |
|--------|-----------------------------------------------------------|-------------------|--------|
| 1      | Lectura de la guía y la rúbrica; creación del repositorio | Repo + estructura | ✓      |

| Semana | Actividad                                                          | Entregable               | Estado                                                 |
|--------|--------------------------------------------------------------------|--------------------------|--------------------------------------------------------|
| 2      | Datos del curso, plan de acción, validación de objetivos           | docs/                    | ✓                                                      |
| 3      | <b>Primer Avance (10 %):</b> contexto, diseño, Tablas 1–2, entorno | Informe Parte I–II       | ✓                                                      |
| 4–5    | Integración del material oficial; Fase 1 (pipeline en rojo)        | Tabla 3 + reportes       | ✓                                                      |
| 6–7    | Fase 2: remediación (un commit por hallazgo)                       | Tabla 4 + pipeline verde | ✓                                                      |
| 8      | Pentest, riesgos (Tabla 5), pruebas (Tabla 6)                      | Tablas 5–6               | ✓                                                      |
| 9      | <b>Segundo Avance (15 %):</b> diagnóstico, remediación, pruebas    | Informe Parte III–IV     | ✓                                                      |
| 10–13  | Protección de rama, revisión de CodeQL, informe final              | Informe Parte V          | ✓ CodeQL revisado · ✓ protección de main (EV-C204-014) |
| 14     | <b>Informe Final (15 %):</b> PDF integrado + repo público          | Entrega                  | ✓ PDF y repo · ⌚ entrega formal a la docente           |

Las fechas exactas de entrega figuran en docs/datos-del-curso.md y siguen marcadas «confirmar fecha con la docente».

## Anexo F — Guía de lectura (evidencias, siglas y archivos)

### Sistema de evidencias

Cada evidencia tiene un ID único **EV-C204-XXX** (ver índice de evidencias, sección inicial). Las evidencias de captura viven en docs/evidencias/capturas/ y las figuras en docs/evidencias/figuras/. El manifiesto docs/evidencias/manifiesto-sha256.txt registra el SHA-256 de cada una (Anexo C).

## Siglas usadas

| Sigla      | Significado                                                              |
|------------|--------------------------------------------------------------------------|
| SAST       | Static Application Security Testing                                      |
| DAST       | Dynamic Application Security Testing                                     |
| SCA        | Software Composition Analysis                                            |
| SBOM       | Software Bill of Materials                                               |
| IAM        | Identity and Access Management                                           |
| JWT / JWKS | JSON Web Token / JSON Web Key Set                                        |
| OAEP       | Optimal Asymmetric Encryption Padding                                    |
| CWE        | Common Weakness Enumeration                                              |
| STRIDE     | Spoofing, Tampering, Repudiation, Information disclosure, DoS, Elevation |
| ALE        | Annualized Loss Expectancy                                               |
| SLE / ARO  | Single Loss Expectancy / Annualized Rate of Occurrence                   |
| SARIF      | Static Analysis Results Interchange Format                               |

## Archivos clave

| Archivo                               | Qué es                                                                                            |
|---------------------------------------|---------------------------------------------------------------------------------------------------|
| docs/informe-maestro.md (.docx, .pdf) | Informe integrado (este documento)                                                                |
| docs/tablas/tabla-1..6                | Tablas de entrega del laboratorio                                                                 |
| docs/plantilla-diagnostico.md         | Plantilla de diagnóstico del curso, completa                                                      |
| docs/validacion-objetivos.md          | Trazabilidad objetivos → dónde → cómo excede                                                      |
| docs/reporte-docente-devcontainer.md  | Reporte a la docente sobre el devcontainer.json del zip oficial (remitido; modificación aprobada) |
| docs/remediacion-playbook.md          | Patrones de corrección de la Fase 2                                                               |
| .github/workflows/devsecops.yml       | Pipeline (5 jobs + CodeQL por default setup)                                                      |
| .devcontainer/devcontainer.json       | Configuración del Codespace                                                                       |
| servidor/                             | Servicio de cifrado (Node.js, 22 pruebas Jest)                                                    |
| scripts/prueba-e2e-keycloak.sh        | Prueba extremo a extremo con                                                                      |

| Archivo                                                  | Qué es                                          |
|----------------------------------------------------------|-------------------------------------------------|
|                                                          | Keycloak real                                   |
| scripts/instalar-evidencia.sh,<br>verificar-evidencia.sh | Instala y comprueba la evidencia de un run      |
| scripts/generar-manifiesto.sh,<br>generar-informe.sh     | Regeneran el manifiesto y el informe (PDF/DOCX) |

## Anexo G — Glosario y convenciones

| Término                     | Definición                                                                                  |
|-----------------------------|---------------------------------------------------------------------------------------------|
| <b>Fase 1 (Diagnóstico)</b> | Subir el proyecto inseguro; documentar los hallazgos en rojo del pipeline                   |
| <b>Fase 2 (Remediación)</b> | Corregir cada hallazgo con un commit; verificar la transición a verde                       |
| <b>Hallazgo</b>             | Vulnerabilidad detectada por una prueba del pipeline o por revisión de código (con CWE)     |
| <b>Riesgo</b>               | Probabilidad × Impacto (escala 1–3)                                                         |
| <b>VULN-n</b>               | Marcador de vulnerabilidad en el código oficial (//[VULN-n])                                |
| <b>FIX-n</b>                | Marcador de corrección en el código remediado (//[FIX-n])                                   |
| <b>Rojo / Verde</b>         | Estado de un job del pipeline: falla / pasa                                                 |
| <b>Falso positivo</b>       | Alerta de una herramienta que no es explotable; se documenta y se suprime con justificación |

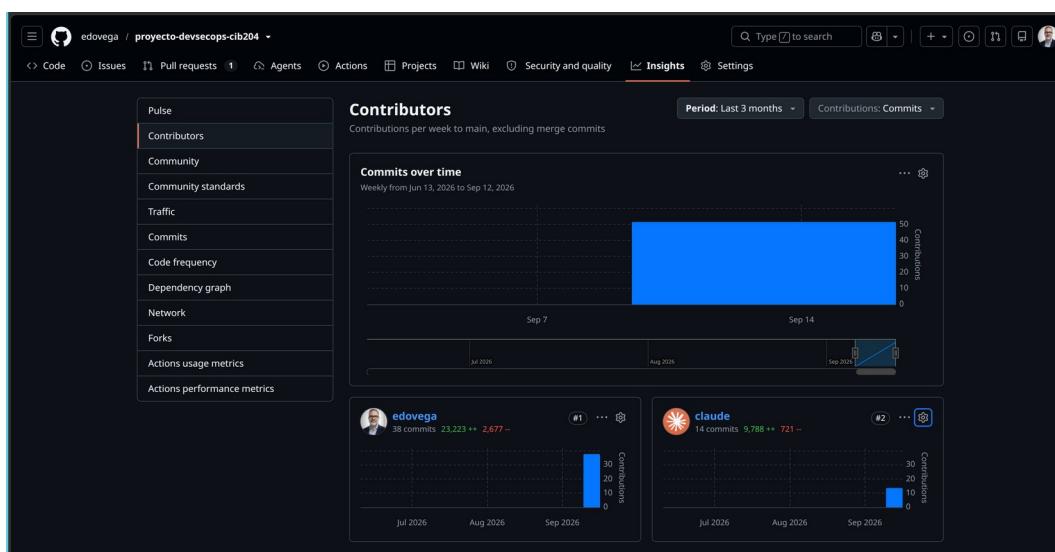
**Convenciones:** - Un commit por corrección, con mensaje descriptivo en español. - Los reportes se descargan como archivos generados y se registran en el manifiesto SHA-256. - El repositorio se creó privado y hoy es público. - Los secretos del laboratorio son ficticios; nunca se suben secretos reales (los valores de práctica se **redactan** en los logs publicados).

## Anexo H — Uso de herramientas de inteligencia artificial

En el desarrollo de este proyecto se utilizaron herramientas de inteligencia artificial (asistentes de codificación y de navegador) como apoyo auxiliar en la depuración de código, la revisión de estándares de seguridad, la elaboración de

documentación y la auditoría de consistencia entre el código, las pruebas y el informe. Las decisiones técnicas y de seguridad, la ejecución y validación del laboratorio en el Codespace, la toma de evidencias y la entrega son responsabilidad de los integrantes del equipo. El código fuente base es el material oficial del curso.

Como evidencia de la proporción de esta participación, la sección *Insights* → *Contributors* del repositorio (rama main, sin commits de fusión; captura del 19 de septiembre de 2026) registra **38 commits a nombre del estudiante** (23 223 líneas añadidas y 2 677 eliminadas), frente a **14 commits asociados a la herramienta de IA** (9 788 líneas añadidas y 721 eliminadas).



*EV-C204-031 — GitHub, Insights → Contributors: 38 commits del estudiante (edovega) y 14 asociados a la herramienta de IA*

---

## Anexo I — Capturas de consola Git por slide (EV-C204-033..051)

Cada captura del PPTX del equipo (EV-C204-018-capturas-consola-git.pptx) está **individualizada** como EV-C204-033..051 en docs/evidencias/capturas/consola-git/ y se incorpora como figura en la sección indicada. Los archivos EV-C204-052 y EV-C204-053 son copias del PPTX y del PDF. La columna «Imagen» es el número de la imagen dentro del PPTX.

| ID          | Archivo                            | Im<br>age<br>n | Qué muestra                                                                                                                                                                                                                          | Sección |
|-------------|------------------------------------|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| EV-C204-033 | EV-C204-033-screenshot-image10.png | 10             | Run #4 (35287858942, e15ebce): Semgrep y Gitleaks  , el resto  | §13.2   |
| EV-C204-034 | EV-C204-034-screenshot-image11.png | 11             | Run #3 (35284491567, 3441e89)                                                                                                                                                                                                        | §13.2   |
| EV-C204-035 | EV-C204-035-screenshot-image12.png | 12             | Run #2 (35283334710, 8129154)                                                                                                                                                                                                        | §13.2   |
| EV-C204-036 | EV-C204-036-screenshot-image13.png | 13             | Run #1 (35280933094, a20bf16), estructura inicial                                                                                                                                                                                    | §13.2   |
| EV-C204-037 | EV-C204-037-screenshot-image14.png | 14             | Run #8 (35365578175), captura «hace 1 hora» (respaldo de EV-C204-048)                                                                                                                                                                | §13.3   |
| EV-C204-038 | EV-C204-038-screenshot-image15.png | 15             | Run #8: sección de archivos generados con 5 archivos generados y huellas SHA-256                                                                                                                                                     | §13.3   |
| EV-C204-039 | EV-C204-039-screenshot-image16.png | 16             | Run #8, captura «hace 2 horas» (respaldo de EV-C204-048)                                                                                                                                                                             | §13.3   |
| EV-C204-040 | EV-C204-040-screenshot-image17.png | 17             | Log de SAST-Semgrep: 23 hallazgos, salida 1                                                                                                                                                                                          | §13.3   |
| EV-C204-041 | EV-C204-041-screenshot-image18.png | 18             | Log de Secretos-Gitleaks: 4 fugas                                                                                                                                                                                                    | §13.3   |
| EV-C204-042 | EV-C204-042-screenshot-image19.png | 19             | Job DAST-OWASP ZAP exitoso                                                                                                                                                                                                           | §13.3   |
| EV-         | EV-C204-043-                       | 1              | Codespace:                                                                                                                                                                                                                           | §8.1    |

| ID          | Archivo                           | Imagen | Qué muestra                                                | Sección             |
|-------------|-----------------------------------|--------|------------------------------------------------------------|---------------------|
| C204-043    | screenshot-image1.png             |        | creation.log y modo de recuperación                        |                     |
| EV-C204-044 | EV-C204-044-screenshot-image2.png | 2      | Recorte del terminal: recuperación y git pull              | §8.1                |
| EV-C204-045 | EV-C204-045-screenshot-image3.png | 3      | Codespace operativo con .devcontainer                      | §8.1                |
| EV-C204-046 | EV-C204-046-screenshot-image4.png | 4      | node v20.20.2 / npm 10.8.2                                 | §8.1 (EV-C204-001)  |
| EV-C204-047 | EV-C204-047-screenshot-image5.png | 5      | Pestaña Actions: 8 ejecuciones en rojo                     | §13.2 (EV-C204-007) |
| EV-C204-048 | EV-C204-048-screenshot-image6.png | 6      | Run #8: resumen de los 6 jobs                              | §13.3               |
| EV-C204-049 | EV-C204-049-screenshot-image7.png | 7      | Run #7 (35303673682, 9a63eb8)                              | §13.2               |
| EV-C204-050 | EV-C204-050-screenshot-image8.png | 8      | Run #6 (35303227701, 9b1bddb): integración del zip oficial | §13.2               |
| EV-C204-051 | EV-C204-051-screenshot-image9.png | 9      | Run #5 (35288102685, 82c3bbe)                              | §13.2               |

## Anexo J — Cómo verificar este informe

Para quien audite (persona o IA), desde la raíz del repositorio:

```
git rev-parse HEAD # commit local
gh run view 35442482331 --json headSha,status,conclusion,event # run
verde de referencia (código 0fc1c11)
sha256sum --check docs/evidencias/manifiesto-sha256.txt #
```

```
todos «OK»  
bash scripts/verificar-evidencia.sh 35442482331      # reportes del  
run == evidencia instalada  
cd servidor && npm ci && npm test                    # 22 pruebas  
bash scripts/prueba-e2e-keycloak.sh                 # 25  
comprobaciones con Keycloak real (requiere Docker)
```

El código evaluado es el del commit 0fc1c11. Los commits posteriores solo modifican documentación y evidencia; cada uno dispara el pipeline, que debe seguir en verde (gh run list --limit 3).